

Σavante

Seguridad y protección en redes de comunicaciones. CNN. Seguridad perimetral. Redes virtuales VPN. Acceso remoto seguro a redes. Seguridad en el puesto de usuario

ÍNDICE

1. Seguridad y protección en redes de comunicaciones	4
1.1. Modelo conceptual de la seguridad	13
1.2. Mecanismos y herramientas de seguridad	15
1.3. Estrategia de seguridad	16
2. Centro Criptológico Nacional (CCN)	21
3. Otras normativas y organismos para seguridad	24
3.1. Secretaría General de Administración Digital (SGAD)	25
3.1.1. Esquema Nacional de Seguridad (ENS)	29
3.1.2. MAGERIT	30
4. Seguridad perimetral	32
4.1. Componentes de la seguridad perimetral	35
4.1.1. Enrutadores y reglas de filtrado	36
4.1.2. Cortafuegos	37
4.1.2.1. Cortafuegos industriales	38
4.1.2.2. Evolución de los Cortafuegos	39
4.1.3. Sistemas VPN	40
4.1.4. Dispositivos de red	40
4.1.5. Servidores	42
4.1.6. Sistemas de Usuario y Sistemas Móviles	45
4.2. Esquema de arquitectura de red	47
4.3. Sistemas de protección de las comunicaciones	49
4.3.1. Sistema de Detección de Intrusiones (IDS)	49
4.3.1.1. Clasificación	50
4.3.1.1.1. En función de qué sistemas monitorizan	51
4.3.1.1.2. En función de cómo lo hacen	52
4.3.1.2. Tipos de software de detección de intrusiones	52
4.3.2. Sistema de Prevención de Intrusiones (IPS)	53
4.3.2.1. Tipos de IPS	54
4.3.2.1.1. HIPS (Host IPS)	54
4.3.2.1.2. NIPS (Network-based Intrusion Prevention System)	54

4.3.2.1.3. NBA (Network Behavior Analysis)	55
4.3.2.1.4. WIPS (Wireless Intrusion Prevention System)	56
4.3.3. Sistema de gestión de eventos e información de seguridad (SIEM)	58
5. Redes privadas virtuales (VPN)	59
5.1. Posibles usos y característica de las conexiones VPN	61
5.2. Tecnologías VPN y protocolos	63
5.2.1. Protocolo L2TP	65
5.2.2. Protocolo IKE para VPN	66
5.2.3. Protocolo WireGuard para VPN	68
5.2.4. OpenVPN (Protocolo y Software)	68
5.3. Tipos de VPN	70
6. Protocolo RADIUS	74
7. Acceso remoto seguro a redes	76
8. Seguridad en el puesto del usuario	79
8.1. Control de acceso a la información	79
8.2. Copias de seguridad	80
8.3. Gestión de contraseñas	81
8.4. Single Sign-On	83
8.5. Antivirus (EPP y EDR)	84
8.5.1. Endpoint Protection Platform (EPP)	84
8.5.2. Endpoint Detection and Response (EDR)	84
9. Bibliografía	85



1. Seguridad y protección en redes de comunicaciones



Fuente: social-media-internet-security-police-thumbail de Piqsels

La protección es imprescindible en cualquier tipo de sistema informático, el avance en comunicaciones y redes es cada vez mayor, y también lo es el Riesgo de los daños que se pueden sufrir, ya que los atacantes avanzan a la misma velocidad que el desarrollo tecnológico.



Recuerda ver las clases emitidas en Temario Audiovisual

Las clases impartidas en directo y disponibles en Campus, en Temario Audiovisual, te ayudarán al entendimiento de la unidad, y además pueden tener información adicional.

[ACCEDE DIRECTAMENTE DESDE AQUÍ](#)

Recordemos que los activos, son los bienes que hay que proteger, como, por ejemplo:

- **Personas.**
- **Hardware.**
- **Software.**



- **Información:**



+ Info

La información es el activo más importante (detrás del personal).

Conforme aumenta la interconexión lo hacen también los riesgos para la información, hasta el punto de que, en ocasiones la responsabilidad de la protección pasa a recaer en el propio usuario de los datos.

A pesar de la importancia demostrada de la seguridad, las pérdidas asociadas a fallos de seguridad continúan creciendo.

Las causas, en un alto porcentaje de los casos, están vinculadas a problemas internos de la Organización, especialmente al uso que los usuarios hacen de los datos.

Objetivos de la seguridad de la información

La seguridad de la información se articula sobre tres dimensiones, que son los pilares sobre los que aplicar las medidas de protección de nuestra información:

- **Disponibilidad de la información.**

La disponibilidad de la información se refiere a que la información esté accesible cuando la necesitemos.

- **Integridad de la información.**

Hace referencia a que la información sea correcta y esté libre de modificaciones y errores.

La información ha podido ser alterada (posiblemente de forma intencionada) o ser incorrecta.

Esto es un problema grave ya que, normalmente, basamos nuestras decisiones en dicha información.

- **Confidencialidad de la información.**

Implica que la información solo sea accesible por el personal autorizado.

Es lo que se conoce como need-to-know.

Este término hace referencia a que la información solo debe ponerse en conocimiento de las personas, entidades o sistemas autorizados para su acceso y que realmente necesiten utilizarla.



Pilares de la protección de la información



+ Info

Según el estándar ISO/IEC 27002.

"La seguridad de la información se puede caracterizar por la preservación de:

- **Confidencialidad:** asegura que el acceso a la información está adecuadamente autorizado.
- **Integridad:** salvaguarda la precisión y completitud de la información y sus métodos de proceso.
- **Disponibilidad:** Asegura que los usuarios autorizados pueden acceder a la información cuando la necesitan".

La evaluación de los activos de información de la organización en relación con estas tres dimensiones de la seguridad determina la dirección a seguir en la implantación y selección de medidas (controles o salvaguardas).

También debemos tener en cuenta que la adopción de un determinado control para mejorar la seguridad en una dimensión puede afectar de forma negativa o positiva a otra de las dimensiones.

Es esencial conocer cuál de estas dimensiones es más importante proteger en cada sistema de información y llegar a una solución de compromiso entre las tres dimensiones.



Ejemplo

Por ejemplo:

Implantar un control de acceso para proteger la confidencialidad en un aparato médico de una sala de operaciones.

Esto produciría un retardo en el acceso a la información.

Por lo tanto, se ve afectada su disponibilidad.



Recuerda

No repudio:

Algunos estándares añaden un objetivo más denominado no repudio. Este objetivo garantiza la participación de las partes en una comunicación.

Ataques

Vamos a ver los principales ataques que puede sufrir un sistema si se aprovechan sus vulnerabilidades. Y vamos a hacerlo de forma gráfica para facilitar su entendimiento.

Partimos de una comunicación normal:



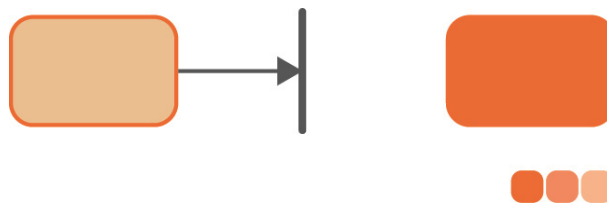
Comunicación normal



Podemos sufrir diferentes ataques:

- **Interrupción** (afecta a la disponibilidad).

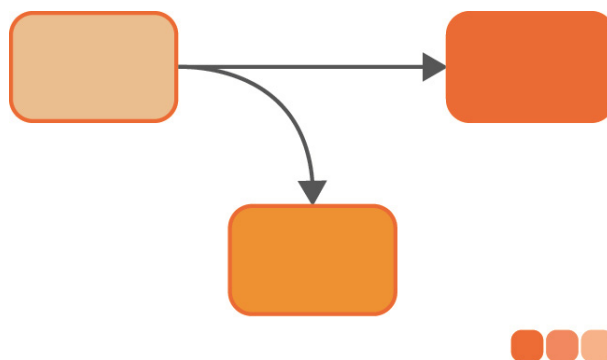
Un recurso del sistema o la red deja de estar disponible debido a un ataque.



Interrupción

- **Intercepción** (afecta a la confidencialidad).

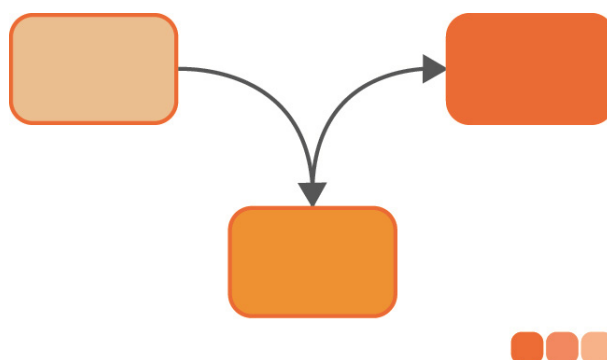
Un intruso accede a la información de nuestro equipo o a la que enviamos por la red.



Intercepción

- **Modificación** (afecta a la integridad).

La información ha sido modificada sin autorización, por lo que ya no es válida.

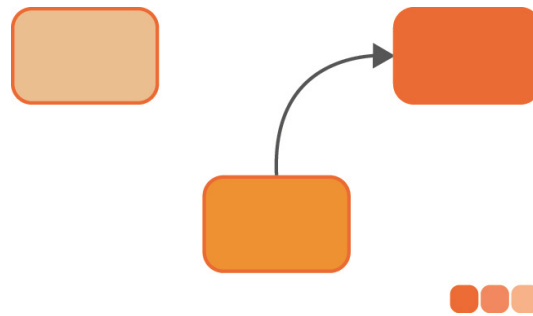


Modificación



- **Fabricación** (puede afectar a los tres).

Se crea un producto (por ejemplo, una página Web) difícil de distinguir del auténtico y que se utiliza para suplantar un organismo o empresa y solicitar información confidencial al usuario.



Fabricación

Amenazas y vulnerabilidades

Una vulnerabilidad es un estado o característica de un activo que permite la consecución de ataques que comprometan la confidencialidad, integridad o disponibilidad de ese mismo activo o de otros activos de la organización.

Son las deficiencias de un activo que pueden ser explotadas por amenazas.



Ejemplo

Ejemplos de Vulnerabilidades:

- Falta de conocimientos del usuario.
- Falta de medidas de seguridad.
- Mala elección de contraseñas.
- Inexistencia de medidas contra incendios.

Una Amenaza es todo elemento o acción capaz de atentar contra la seguridad del sistema de información.

Las amenazas surgen a partir de la existencia de vulnerabilidades, una amenaza sólo puede existir si existe una vulnerabilidad que pueda ser aprovechada.



La amenaza es la posibilidad de que alguien pueda explotar la vulnerabilidad.

Las amenazas pueden clasificarse en dos tipos:

- **Intencionadas.**

Se intenta producir un daño deliberadamente.

- **No intencionadas.**

Se producen por omisiones o acciones que no buscan explotar la vulnerabilidad, pero que ponen en riesgo los activos y pueden producir un daño.



Ejemplo

Ejemplos de amenazas no intencionadas:

- Desconocimiento (mala formación).
- Fallo de un equipo.
- Desastres naturales.

Ejemplos de amenazas intencionadas:

- Robo.
- Fraude mediante técnicas de ingeniería social.

Los usuarios



Los usuarios constituyen el elemento más vulnerable en el marco de la seguridad de las tecnologías de la información y comunicaciones.



Las personas son un objetivo prioritario para cualquier atacante que quiera acceder de forma no autorizada a la información.

Uno de los ataques más habituales contra la seguridad de la información a través de las personas es sin duda la ingeniería social.

Consiste en la manipulación de las personas para que voluntariamente realicen actos que normalmente no harían.

Posiblemente sea el ataque más sencillo, con menos riesgos para el atacante y de los más efectivos.

El éxito de estos ataques se deriva de:

- La ingenuidad de los usuarios.
- El desconocimiento de buenas prácticas de seguridad.
- Falta de concienciación en tema de seguridad por parte de los usuarios.

Cuanto mejores sean las medidas técnicas, más se centrarán los ataques en las personas, dada la complejidad de la vía técnica.

Planificación de la seguridad

La **complejidad** de la protección de la información se ha incrementado por algunos factores como:

- Las redes públicas (internet) están fuera del control de la organización.
- La movilidad requerida por el personal de la Organización.
- El riesgo de ataques remotos de terceros contra los datos.

No existe la seguridad absoluta (probabilidad del 100%).

El **grado de seguridad** se consigue mediante una solución de compromiso entre varios factores:

- Nivel de seguridad.
- Recursos disponibles.
- Funcionalidad deseada.



Para implementar la seguridad en una Organización de forma adecuada se deben planificar y tener en cuenta los **aspectos** siguientes:

- **Análisis de Riesgos.**

Estudio de los riesgos existentes y valoración de las consecuencias de estos sobre los activos de información.

- **Gestión de Riesgos.**

Valoración de los diferentes controles (elementos que reducen el riesgo) y decisión sobre los más adecuados en cada caso. Esto permite determinar el riesgo residual.

"El riesgo residual es el riesgo que queda una vez aplicadas las medidas de reducción de riesgo."

- **Política de Seguridad.**

Adaptación de la operativa habitual de la Organización a las medidas de seguridad requeridas.

- **Mantenimiento.**

Control continuo de la eficiencia de las medidas de seguridad desplegadas y adecuación de estas a nuevos escenarios de riesgo.

- **Planes de Contingencia.**

Determinación de las medidas a adoptar ante un incidente de seguridad.



+ Info

Consulta la información indicada por el organismo CCN:

CCN-STIC-201: Organización y Gestión para la Seguridad de las TIC.

<https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/45-ccn-stic-201-estructura-de-seguridad/file.html>



1.1. Modelo conceptual de la seguridad

Si hablamos de seguridad podemos referirnos a tres aspectos diferentes:

- **Condición.**

La condición en concepto de seguridad de un activo (si está seguro o no).

- **Medidas.**

La seguridad como un conjunto de medidas de protección.

- **Organización.**

Organización o grupo de personas responsables de proporcionar la condición de seguridad a los activos.

La seguridad intenta proteger los activos. Por lo tanto, según los activos a proteger se pueden utilizar distintos términos:

- **STIC.**

Seguridad de las tecnologías de información y las comunicaciones.

- **SSI.**

Seguridad de los Sistemas de Información.

- **COMSEC.**

Seguridad de los Sistemas de Comunicaciones.

- **ELSEC.**

Seguridad electrónica.

Algunos autores engloban COMSEC y ELSEC en el término SIGSEC (Seguridad de las señales).

STIC

Según la definición del término STIC, la seguridad de la información y de los sistemas que la tratan puede conseguirse protegiendo cada uno de los recursos que componen la configuración de dichos sistemas.



De este modo, las medidas de seguridad, en función del objeto de protección en cada caso, pueden clasificarse en:

- **TRANSEC.**

Medidas que aseguran los canales de transmisión (Seguridad de las Transmisiones).

Hace referencia a la prevención contra la obtención de información por medio de la interceptación, radiolocalización y análisis de las señales electromagnéticas.

- **COMPUSEC.**

Medidas que protegen el proceso automático de datos (Seguridad de los Ordenadores).

- **EMSEC.**

Medidas que protegen a los equipos frente a la emisión de radiaciones no deseadas (Seguridad de las Emisiones).

- **NETSEC.**

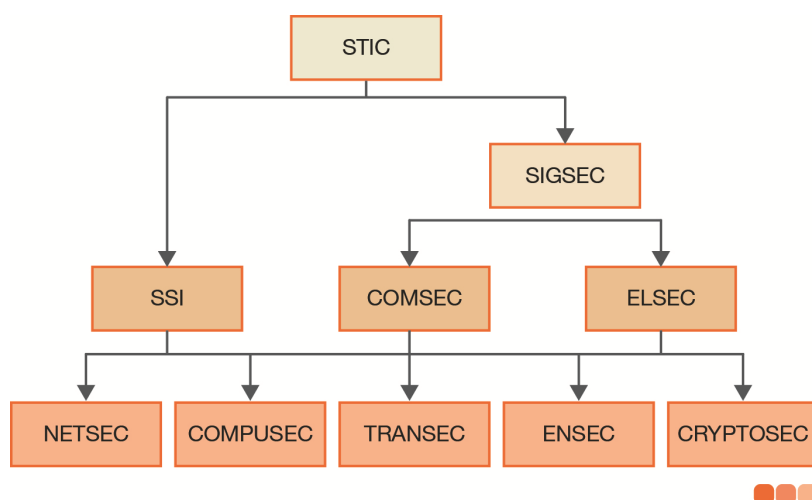
Medidas que protegen los elementos de red (Seguridad de las Redes).

Hace referencia a la protección de las redes contra la modificación, destrucción o revelación de la información mientras circula por ellas.

- **CRYPTOSEC.**

Medidas que aseguran que la información está protegida mediante procedimientos criptográficos adecuados (Seguridad Criptológica).

Vamos a verlo visualmente para entenderlo mejor:



Nomenclatura de los tipos de seguridad según el activo protegido



1.2. Mecanismos y herramientas de seguridad



Salvaguarda (o control) es cualquier medida que reduzca el riesgo.

Se debe proteger convenientemente la información y los sistemas que la tratan desde dos perspectivas:

- Según el carácter del control:
 - Técnico.
 - Organizativo.
 - Normativo.
- Según el punto en que aportan seguridad:
 - Prevención.
 - Detección.
 - Respuesta.

Según el carácter del control

- **Técnico.**

Los controles técnicos pretenden proteger desde un punto de vista operativo, tanto física como lógicamente, la información y los sistemas que la procesan frente a amenazas de cualquier tipo.

- **Organizativo.**

Las medidas de carácter organizativo se ocupan de dictar controles de índole administrativa y organizativa para instrumentar, reforzar o complementar las restantes medidas.

Algunas de estas medidas son:

- Asignación de responsabilidades.
- Establecimiento de política de seguridad.



- Política de personal.
- Análisis de riesgos.
- Planes de contingencia.
- **Normativo.**

Las medidas de protección normativa comprenden los aspectos de cumplimiento obligatorio de aplicación en cada caso, en especial desde el punto de vista legal.

Según el punto en que aportan seguridad

- **Prevención.**

Aumentan la seguridad de un sistema de información durante el funcionamiento normal de éste, previniendo la ocurrencia de violaciones a la seguridad.

Disuaden a los posibles atacantes de no realizar el ataque.

- **Detección.**

Se utilizan para detectar violaciones de la seguridad o intentos de violación.

- **Respuesta.**

Se aplican cuando se ha detectado una violación de la seguridad.

Algunos controles pueden aportar seguridad en más de un punto.

1.3. Estrategia de seguridad

El diseño de una estrategia de seguridad depende de la actividad desarrollada por la Organización.

Indistintamente de esto, hay una serie de pasos comunes a seguir:

1. Crear una política de seguridad.
2. Realizar un análisis de riesgos.
3. Aplicar las salvaguardas correspondientes.
4. Concienciar a los usuarios.



Política de seguridad

La política de seguridad debe definir:

- Estado de la información.
- Objetivo general.
- Los objetivos específicos que se deberán conseguir.
- Las tecnologías de la información, destacando su importancia para la Organización.
- El período de validez de la política.
- Los recursos con los que contamos.

Análisis de riesgos

Con el análisis de riesgos intentamos identificar los problemas a los cuales está expuesta la información a partir de:

- Los activos de la Organización.
- Las amenazas que existen sobre los mismos.
- Las probabilidades de que éstas se materialicen.
- El impacto asociado a la materialización.

Es necesario revisar y actualizar periódicamente este análisis de riesgos tomando como base de partida:

- El último realizado.
- Las salvaguardas implementadas.
- Las estadísticas de ataques recibidos (cantidad, impacto, etc.).

Aplicar Salvaguardas

Una vez decididas las medidas a adoptar y el riesgo residual aceptable, se deben establecer las salvaguardas.

La gestión de riesgos utiliza los resultados del análisis de riesgos para seleccionar e implantar los controles adecuados para mitigar los riesgos identificados.



Se puede dividir estos controles en 3 tipos de medidas:

- **Medidas preventivas.**

Su objetivo es reducir el riesgo.

- **Protección Física:**

- » Guardias.
 - » Control de acceso.
 - » Protección hardware.
 - » Etc.

- **Medidas Técnicas:**

- » Cortafuegos.
 - » Detectores de intrusos.
 - » Criptografía.
 - » Etc.

- **Medidas Procedimentales:**

- » Cursos de mentalización.
 - » Actualización de conocimientos.
 - » Normas de acceso a la información.
 - » Etc.

- **Medidas de detección.**

Su objetivo es identificar los riesgos.

- **Protección Física:**

- » Sistemas de vigilancia.
 - » Sensores de movimiento.
 - » Etc.



- **Medidas Técnicas:**
 - » Control de acceso lógico.
 - » Sesión de autenticación.
 - » Etc.
- **Medidas Procedimentales:**
 - » Monitorización de auditoría.
 - » Etc.

- **Medidas de respuesta.**

Su objetivo es impedir o reducir el impacto sobre los activos.

- **Protección Física:**
 - » Sistemas de alimentación ininterrumpida (SAIs).
 - » Etc.
- **Medidas Técnicas:**
 - » Antivirus.
 - » Auditorías.
 - » Copias de seguridad.
 - » Etc.
- **Medidas Procedimentales:**
 - » Planes de contingencia.
 - » Etc.

La formación y concienciación del personal es uno de los objetivos fundamentales que se deben perseguir.

Esto se consigue con la implementación de un programa de concienciación en seguridad.

Los diferentes usuarios de la Organización deben asumir su responsabilidad en la protección de la información y comprender que esto no es sólo competencia de los especialistas en seguridad.



Programa de Concienciación en Seguridad

Un programa de concienciación debe perseguir dejar claro no sólo cómo proteger los activos de la Organización sino también por qué es importante su protección y cómo los usuarios se convierten en la primera barrera de seguridad para ellos.

La implementación del programa ayuda a minimizar los costes ocasionados por los incidentes de seguridad dado que actúa directamente sobre uno de los eslabones más débiles en la cadena de seguridad, los usuarios.



Ejemplo

Programas HCL AppScan.

Anteriormente conocido como IBM AppScan, es una familia de pruebas de seguridad web y herramientas de monitoreo.

AppScan está diseñado para probar las aplicaciones web en busca de vulnerabilidades de seguridad durante el proceso de desarrollo, cuando es menos costoso solucionar dichos problemas.

También hay herramientas para la auditoria informática.



Ejemplo

CLARA:

Herramienta para analizar las características de seguridad técnicas definidas a través del Real Decreto 3/2010 por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica, es funcional exclusivamente en sistemas Windows.



2. Centro Criptológico Nacional (CCN)

El Centro Criptológico Nacional (CCN) es un organismo del Estado español adscrito al Centro Nacional de Inteligencia que se dedica a criptoanalizar y descifrar por procedimientos manuales, medios electrónicos y criptofonía, así como realizar investigaciones tecnológico-criptográficas y formar al personal especializado en criptología. El CCN quedó legalmente regulado por el Real Decreto 421/2004 el 12 de marzo.

El CCN no es una agencia independiente del CNI, sino que, está integrado en el servicio de inteligencia español, siendo parte y responsabilidad de éste (siguiendo el modelo de Alemania o Francia).

Las funciones son:

- Elaborar y difundir normas, instrucciones, guías y recomendaciones para garantizar la seguridad de los sistemas de las tecnologías de la información y las comunicaciones de la administración del estado.
- Formar al personal de la administración especialista en el campo de la seguridad de los sistemas de las tecnologías de la información y las comunicaciones a través del CCN-CERT.
- Constituir el Organismo de Certificación del Esquema Nacional de Evaluación y Certificación de la Seguridad de las Tecnologías de Información.
- Valorar y acreditar la capacidad de los productos de cifra y de los sistemas de las tecnologías de la información para procesar, almacenar o transmitir información de forma segura.
- Coordinar la obtención y desarrollo de la tecnología de seguridad.
- Proteger la información clasificada.
- Establecer relaciones con órganos similares de otros países.

Dentro del CCN se encuentran dos partes integradas:

- El Organismo de Certificación (OC) del Esquema Nacional de Evaluación y Certificación de la Seguridad de las Tecnologías de Información (ENECSTI).
- El Centro Criptológico Nacional Computer Emergency Response Team (CCN-CERT).

Es el organismo español, creado en 2006, encargado de contribuir a la ciberseguridad de la administración pública, los organismos públicos y empresas estratégicas del país.

El CCN-CERT presta los siguientes servicios a las administraciones públicas y empresas estratégicas españolas, y pueden consultarse en su web.

- Gestión de incidentes.
- Sistema de alerta temprana, SAT.
- Formación y sensibilización.



- Guías de seguridad.
- Informes de ciberseguridad.
- Soluciones.

Las soluciones de Ciberseguridad, tratan la coordinación, promoción y desarrollo de soluciones que garanticen la seguridad de los sistemas y contribuyan a una mejor gestión de la ciberseguridad frente a los ciberataques.

Estas soluciones tienen nombre de mujer (Excepto CCNDroid):

- » **ADA**: Plataforma de análisis avanzado de malware.
 - » Integra las capacidades de análisis dinámico (MARTA) y las capacidades de análisis estático (MARÍA), e incluye además capacidades adicionales orientadas al enriquecimiento de los resultados obtenidos.
 - » Solución para controlar, gestionar y acceder a los resultados de todas las tecnologías de análisis que integra desde un solo interfaz unificado.
- » **AMPARO**: Implantación de seguridad y conformidad del ENS.
- » **ANA**: Automatización y normalización de auditorías.
- » **ATENEA**: plataforma del CCN-CERT para comprobar los conocimientos que se tienen sobre seguridad en diferentes temáticas.
- » **CARLA**: Protección y trazabilidad del dato.
- » **CARMEN**: Defensa de ataques avanzados/APT.
- » **CCNDroid**: Herramientas de seguridad para Android.
 - » CCNDroid Wiper: para el borrado seguro de ficheros.
 - » CCNDroid Crypter: para el cifrado de ficheros con distintos algoritmos (incluido PGP).
- » **CLARA**: Auditoría de Cumplimiento ENS/STIC en Sistemas Windows.
- » **CLAUDIA**: Herramienta para la detección de amenazas complejas en el puesto de usuario.
- » **microCLAUDIA**: Herramienta para la detección de amenazas complejas en el puesto de usuario.
- » **ELENA**: Simulador de Técnicas de Cibervigilancia.



- » **EMMA:** Visibilidad y control sobre la red.
- » **GLORIA:** plataforma para la gestión de incidentes y amenazas de ciberseguridad a través de técnicas de correlación compleja de eventos. Basado en los sistemas SIEM (Security Information and Event Management). Gestor de logs para responder ante incidentes y amenazas.
- » **INES:** solución desarrollada por el CCN para la gobernanza de la ciberseguridad, que permite evaluar regularmente el estado de la seguridad de los sistemas TIC de las entidades, organismos y organizaciones.

Existen dos modalidades de INES:

- » Entidad matriz: entidad con entidades vinculadas o dependientes de ella.
- » Entidad individual: una única entidad sin entidades vinculadas o dependientes.
- » **IRIS:** conocer el estado de la ciberseguridad en tiempo real del sector público y la situación de la ciberamenaza a nivel nacional.
- » **LORETO:** Plataforma de Colaboración de Contenidos (CCP-Content Collaboration Platforms) para mejorar la productividad, al permitir impulsar cambios en los procesos de trabajo, haciéndolos más eficientes a la hora de colaborar con usuarios internos y externos.
- » **LUCIA:** (Listado Unificado de Coordinación de Incidentes y Amenazas). Herramienta para la Gestión de Ciberincidentes con la que se quiere mejorar la coordinación entre el CERT Gubernamental Nacional y los distintos organismos y organizaciones con las que colabora. Estado de la ciberseguridad.
- » **MARTA:** Análisis avanzados de ficheros.

Análisis avanzados de ficheros.

Plataforma avanzada de multi-sandboxing para detectar ficheros que puedan tener un comportamiento malicioso.

Sandboxing se refiere un entorno controlado, a la ejecución de un código que puede ser malicioso, en una máquina virtual aislada para asegurar que no pueda afectar al sistema.

El término y la idea de Sandboxing, tiene su origen en las "cajas de arena" donde los niños juegan con la arena en un entorno controlado. Se traduce sandboxing como "caja segura".

- » **MONICA:** Gestión de eventos e información de seguridad.
- » **OLVIDO:** para que el usuario pueda borrar de forma segura distintos elementos, con tareas de sobre escritura y borrado sobre los sistemas de archivos y discos.



- » **PILAR:** Herramientas de análisis y gestión de riesgos de sistemas de información. Hay diferentes versiones:
 - » PILAR: Versión íntegra.
 - » PILAR Basic: para PYMES y Administración Local.
 - » μ PILAR: Versión reducida.
 - » RMat: Personalización de herramientas.
 - » **REYES:** portal centralizado para Intercambio de Información de Ciberamenazas, para agilizar la labor de análisis de ciberincidentes y compartir información de ciberamenazas.
 - » **ROCIO:** Inspección de Operación. Auditoría de configuraciones de dispositivos de red. Verificar el nivel de seguridad equipos de comunicaciones (enrutadores, conmutadores y cortafuegos).
 - » **VANESA:** Grabaciones y emisiones de vídeo en streaming.
- Cumplimiento del ENS.
 - Auditorías web.
 - Capacidad forense y de ingeniería inversa.

Puedes consultar toda esta información, y es recomendable que lo hagas en la web oficial:
<https://www.ccn-cert.cni.es/>

ATENEA, Plataforma de desafíos de seguridad

ATENEA se ha desarrollado por el CCN-CERT para poner a prueba los conocimientos del campo de la ciberseguridad de cualquier persona que lo desee, la cual debe registrarse.

Se ofrecen desafíos de seguridad en diversas temáticas: Criptografía y Esteganografía; Exploiting, Forense, Análisis de tráfico, Reversing, etc.

3. Otras normativas y organismos para seguridad

El avance continuo de las TIC conlleva también el aumento de los atacantes para realizar diferentes operaciones fraudulentas, lo que hace que los organismos oficiales estén también controlando todo aquello relacionado con la seguridad, a través de normas, guías y Real Decretos, que van ampliando o modificando.



Algunos de los más destacados son:

- **Secretaría General de Administración Digital (SGAD).**

https://administracionelectronica.gob.es/pae_Home/

- **Real Decreto 43/2021**, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

<https://avancedigital.mineco.gob.es/gl-es/Servicios/seguridad-redes/Paginas/seguridad-redes-sistemas-informacion.aspx>

https://www.boe.es/diario_boe/txt.php?id=BOE-A-2021-1192

- **Real Decreto-ley 12/2018**, de 7 de septiembre, de seguridad de las redes y sistemas de información.

https://www.boe.es/diario_boe/txt.php?id=BOE-A-2018-12257

3.1. Secretaría General de Administración Digital (SGAD)

La Secretaría General de Administración Digital (SGAD) de España, antes era conocida como Dirección de Tecnologías de la Información y las Comunicaciones (DTIC).

La SGAD, con rango de Subsecretaría, y dependiente del Ministerio de Asuntos Económicos y Transformación Digital, asume la dirección, coordinación y ejecución de las competencias atribuidas al Departamento en materia de transformación digital de la administración.

Está adscrito a la Secretaría de Estado de Digitalización e Inteligencia Artificial.

La SGAD, es el órgano encargado de impulsar el proceso de racionalización de las tecnologías de la información y de las comunicaciones en el ámbito de la Administración General del Estado y sus Organismos Públicos, en los términos establecidos en los siguientes Reales Decretos:

- Real Decreto 139/2020, de 28 de enero, por el que se establece la estructura orgánica básica de los departamentos ministeriales.
- Real Decreto 403/2020, de 25 de febrero, por el que se desarrolla la estructura orgánica básica del Ministerio de Asuntos Económicos y Transformación Digital.
- Real Decreto 806/2014, de 19 de septiembre, sobre organización e instrumentos operativos de las TIC en la AGE.

La SGAD ejerce directamente las siguientes funciones:

- Elaboración de la estrategia en materia de Administración Digital y Servicios Públicos Digitales de la Administración General del Estado y sus Organismos Públicos, así como del proceso de innovación, y el establecimiento de las decisiones y directrices necesarias para su ejecución.



- Actuación como órgano referente nacional e interlocutor ante organismos e instituciones europeas e internacionales en el ámbito de la Administración Digital.
- Elaboración y tramitación de los proyectos de disposición de carácter general en materia de organización y procedimiento que afecten a la actuación y funcionamiento del sector público por medios electrónicos.

Esto lo realiza conjuntamente con la Dirección General de Gobernanza Pública.

- En los aspectos relativos a la administración electrónica, y en coordinación con los departamentos ministeriales y sus organismos dependientes, así como con otras administraciones públicas:
 - Colaboración con la Dirección General de Gobernanza Pública en la identificación, diseño, e impulso de programas y proyectos para facilitar el acceso de los ciudadanos y las empresas a los servicios públicos.
 - Elaboración y desarrollo de programas de atención, información y asistencia a los ciudadanos a través de los distintos canales disponibles.
- La colaboración con la Dirección General de Racionalización y Centralización de la Contratación en la gestión centralizada de la contratación en el ámbito competencial de la Secretaría General de Administración Digital.

Estructura de la SGAD

De la Secretaría General dependen los siguientes órganos, a través de los cuales ejerce el resto de sus funciones:

- **La Subdirección General de Planificación y Gobernanza de la Administración Digital.**

Le corresponde:

- La definición, desarrollo, despliegue y supervisión de la estrategia en materia de transformación digital en el ámbito de la Administración del Estado.
- La participación y coordinación de los órganos colegiados TIC.
- El ejercicio de las competencias que corresponden al Coordinador Nacional de la pasarela digital única europea.

- **La Subdirección General de Impulso de la Digitalización de la Administración.**

Le corresponde:

El análisis de requerimientos, diseño, implantación y la gestión compartida, ya sea mediante coordinación o prestación directa, de los servicios comunes de sistemas de información y comunicación para la Administración General del Estado y sus organismos públicos.



La Subdirección General de Planificación y Gobernanza de la Administración Digital y la Subdirección General de Impulso de la Digitalización de la Administración se encargan conjuntamente de:

- El diseño técnico, implantación y gestión de los medios y servicios digitales necesarios para evolucionar los servicios públicos actuales hacia servicios públicos universales de calidad, orientados a los ciudadanos y empresas, promoviendo la incorporación de las tecnologías de la información y las comunicaciones y la digitalización a los procedimientos administrativos y la adaptación de la gestión pública al uso de medios digitales, en colaboración con la Secretaría de Estado de Función Pública (SEFP).
- La definición de las políticas y estrategias en relación con la gestión de datos en la Administración General del Estado y sus Organismos Públicos y desarrollar acciones para coordinar a los diferentes organismos y entidades con el objetivo de conseguir una efectiva implementación de las mismas para la prestación de los servicios públicos digitales, así como la elaboración y propuesta de normativa referente a la reutilización de la información del sector público.
- La elaboración, desarrollo, implantación, coordinación y seguimiento del Catálogo de tipos de datos compartibles para facilitar la localización y acceso a información elaborada por la Administración del Estado que sean necesarios a efectos de un procedimiento administrativo, mediante el uso de instrumentos como la Plataforma de Intermediación de Datos, y para implementar los mecanismos de conexión con la pasarela digital única de la Unión Europea.
- La definición de estándares, de directrices técnicas y de gobierno TIC, de normas de calidad e interoperabilidad de aplicación a las Administraciones Públicas.
- La colaboración con la Dirección General de Gobernanza Pública en la gobernanza y gestión del registro de funcionarios habilitados, del registro electrónico de apoderamientos, del registro electrónico general de la Administración General del Estado, del Sistema de Información Administrativa de los procedimientos en el ámbito de la Administración General del Estado y en la definición funcional y gobernanza del sistema de notificaciones.
- **La Subdirección General de Infraestructuras y Operaciones.**

Le corresponde:

- El estudio y planificación de la evolución de las plataformas tecnológicas para la prestación de servicios comunes, incluidos:
 - » Los declarados compartidos; el diseño, provisión, explotación y evolución de los centros de proceso de datos de referencia para la prestación de servicios comunes.
 - » El diseño, provisión y explotación de los servicios y las infraestructuras de comunicaciones unificadas de la Administración General del Estado y sus organismos públicos.
 - » La Red SARA, que interconecta con otras administraciones públicas y la Unión Europea.



- » El diseño, provisión y explotación de las infraestructuras tecnológicas y de los servicios de seguridad necesarios para la prestación de servicios comunes, incluidos los declarados compartidos, que correspondan a la Secretaría General.
- » La colaboración con la Dirección General de Gobernanza Pública en la gobernanza del teléfono 060.

• **La Subdirección General de Servicios Digitales para la Gestión.**

Le corresponde:

- El análisis de requerimientos, diseño, desarrollo, pruebas y mantenimiento de las aplicaciones y herramientas necesarias para dar soporte a los servicios horizontales de la Administración General del Estado y sus Organismos Públicos, entre otros, los relativos a la gestión de recursos humanos.
- El diseño técnico y gestión de las plataformas tecnológicas que los soportan, en coordinación con la SEFP, en relación con la gestión del portal y sede electrónica del personal al servicio de la Administración General del Estado (FUN-CIONA) y su autenticación.
- La provisión de aplicaciones y servicios en materia de tecnologías de la información y comunicaciones prestados a las Delegaciones y Subdelegaciones del Gobierno y a las Direcciones Insulares en todos sus ámbitos de actuación, en los términos que establezca la Dirección General de la Administración General del Estado en el Territorio, en coordinación con los ministerios implicados por cuestión de la materia.

• **La Subdirección General de Presupuestos y Contratación TIC.**

Le corresponde:

- La elaboración, en colaboración con la Dirección General de Racionalización y Centralización de la Contratación, de propuestas relacionadas con las políticas de adquisiciones de bienes informáticos y en la contratación pública de estos bienes y servicios TIC en la Administración General del Estado y sus Organismos Públicos.
- Todo lo relacionado con la gestión económico-presupuestaria en el ámbito de la Secretaría General y el estudio, planificación, impulso y seguimiento de los procesos de contratación en materia TIC y aquellos otros ámbitos relacionados.
- Es responsable de la definición y gestión de un sistema común de imputación de costes TIC para toda la Administración General del Estado y sus Organismos Públicos.

• **La División de Planificación y Coordinación de Ciberseguridad.**

Le corresponde:

- La dirección técnica y estratégica del Centro de Operaciones de Ciberseguridad de la Administración General del Estado y sus organismos.



- La definición de estándares, de directrices técnicas y de gobierno TIC, de normas de seguridad de aplicación a las Administraciones Públicas y la realización de propuestas e interlocución con el Centro Criptológico Nacional en el desarrollo de guías de seguridad.
- **El Gabinete Técnico**, como órgano de apoyo y asistencia inmediata al titular de la Secretaría General.



Atención

Debes conocer el portal web, y todo lo que ofrece en relación a la seguridad informática.

También es importante, como ya has visto en otras unidades, la Métrica v.3 (Metodología de Planificación, Desarrollo y Mantenimiento de sistemas de información), y Observatorio de Accesibilidad Web.

https://administracionelectronica.gob.es/pae_Home/

3.1.1. Esquema Nacional de Seguridad (ENS)

Es una normativa que tiene por objetivo establecer la política de seguridad en la utilización de medios electrónicos relacionados con la Administración Pública, y está constituido por principios básicos y requisitos mínimos que permitan una protección adecuada de la información.

El ámbito de aplicación del Esquema Nacional de Seguridad comprende:

- Todo el Sector Público, en los términos previstos en el artículo 2 de la Ley 40/2015, de 1 de octubre.
- Los sistemas que tratan información clasificada, sin perjuicio de la aplicación de la Ley 9/1968, de 5 de abril, de Secretos Oficiales.
- Los sistemas de información de las entidades del sector privado cuando presten servicios o provean soluciones a las entidades del sector público para el ejercicio de sus competencias y potestades administrativas.

El Esquema Nacional de Seguridad fue establecido en el artículo 42 de la Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los Servicios Públicos y regulado por el Real Decreto 3/2010, de 8 de enero. Posteriormente, fue modificado por el Real Decreto 951/2015 para actualizarlo a la luz de la experiencia obtenida en su implantación, de la evolución de la tecnología y las ciberamenazas y del contexto regulatorio internacional y europeo.



En mayo de 2022 entró en vigor una nueva versión del ENS (fecha a partir de la que los sistemas ya existentes disponían de 24 meses para adaptarse a los cambios).

Dispones de la información en los siguientes enlaces:

- https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx
- Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad.
<https://www.boe.es/eli/es/rd/2022/05/03/311/con>

3.1.2. MAGERIT

MAGERIT versión 3, es la Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información.

Fue elaborada en su día por el antiguo Consejo Superior de Administración Electrónica.

Actualmente, es mantenida por la Secretaría General de Administración Digital (Ministerio de Asuntos Económicos y Transformación Digital) con la colaboración del Centro Criptológico Nacional (CCN).

Su objetivo es minimizar los riesgos de la implantación y uso de las Tecnologías de la Información, enfocada a las Administraciones Públicas, para lo que ofrece una aplicación para el análisis y gestión de riesgos de un sistema de información.

Método de Análisis de Riesgos (MAR)

Constituye el núcleo del enfoque de Magerit v3 proporcionando una estructura sistemática y bien definida para evaluar los riesgos asociados con los activos de información, las amenazas que los acechan y las vulnerabilidades presentes en los sistemas.

El MAR se basa en una serie de pasos bien definidos, que incluyen:

- La identificación y valoración de activos.
- La identificación y análisis de amenazas.
- La evaluación de vulnerabilidades.
- La estimación de riesgos.

Este método permite a los profesionales de la seguridad tomar decisiones informadas y priorizar las medidas de protección necesarias para mitigar los riesgos identificados.



Proyectos de análisis de riesgos (PAR)

Estos proyectos son implementaciones específicas del MAR en entornos concretos, y se llevan a cabo en organizaciones para evaluar los riesgos asociados con sus sistemas de información y establecer medidas de seguridad adecuadas.

Los PAR se inician con la definición de los objetivos y alcance del proyecto, seguidos de la identificación y valoración de activos críticos, amenazas relevantes y vulnerabilidades existentes.

Permiten, a través de un enfoque sistemático, identificar los riesgos más significativos y diseñar estrategias de mitigación adecuadas.

Los resultados obtenidos de los PAR proporcionan una base sólida para la toma de decisiones en materia de seguridad.

Plan de Seguridad (PS)

Es el documento final que se deriva del proceso de análisis de riesgos y define las medidas de seguridad necesarias para proteger los activos de información de una organización. Se actualiza periódicamente para reflejar los cambios en el entorno tecnológico y las nuevas amenazas emergentes.

Se basa en los resultados obtenidos del análisis de riesgos y proporciona una visión clara de las acciones y controles de seguridad que deben implementarse.

Incluye políticas, procedimientos, directrices y normas específicas que guían la gestión de la seguridad de la información en la organización.

Los planes de seguridad pueden recibir diferentes nombres según el contexto y el enfoque específico de la organización, siendo algunos de los más comunes para los planes de seguridad:

- Plan de mejora de la seguridad de la información.
- Plan Director de Seguridad.
- Plan estratégico de ciberseguridad.
- Plan de seguridad de la información digital.
- Plan de Adecuación.

Este es el nombre específico utilizado para el plan de seguridad en el contexto del **Esquema Nacional de Seguridad (ENS)** en España.

El ENS establece los requisitos y directrices para la seguridad de la información en las administraciones públicas en España, y en este marco, se espera que las organizaciones desarrollen y mantengan un Plan de Adecuación que cumpla con los criterios establecidos en el ENS.

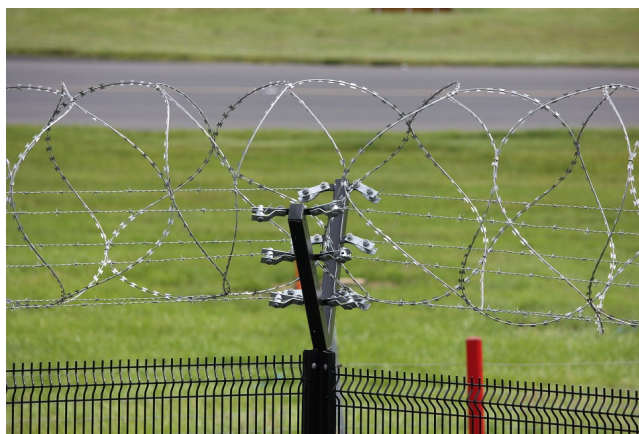


+ Info

Existen herramientas comerciales de Análisis y Gestión de Riesgos basadas en Margerit, como son:

- GxSGSI: homologada por la Agencia de la Unión Europea para la Ciberseguridad.
- R-Box.
- SECITOR: de alto nivel que permite la gestión integral de la Seguridad de la Información siendo un sistema multimarco (ISO 27001, Protección de datos, ENS, ISO 19001, etc.), además de una monitorización en tiempo real de la seguridad de la organización.
- EAR / PILAR: Entorno de análisis de riesgos.

4. Seguridad perimetral



Asegurar el perímetro es una de las estrategias defensivas más eficaces y comúnmente utilizadas en el campo de la seguridad.

Reducir la superficie de exposición, crear puntos controlados de acceso y centrar las defensas en esos puntos permite optimizar la capacidad defensiva.



Los cortafuegos son dispositivos que separan distintas áreas con distintos requisitos de seguridad o niveles de riesgo y que controlan el flujo de tráfico entre ellas.

La seguridad proporcionada por el cortafuegos, se puede ampliar usando distintas técnicas:

- Aumentar la "inteligencia" de los cortafuegos.
- Cifrado.
- Certificados digitales.
- Sistemas de detección y prevención de intrusiones.
- Sistemas de análisis de contenidos.
- Etc.

Hay que tener claro que la seguridad perimetral no debe entenderse como la separación de la organización con internet.

En realidad, se deben separar todas las áreas que tengan distintos requisitos de seguridad.

Es necesario hacer un análisis de cuántos niveles distintos de seguridad deben establecerse en la Organización.

Identificación de amenazas

Para que la seguridad perimetral sea eficiente debemos conocer:

- Qué activos se quiere defender.
- Cuán valiosos son estos activos.
- Cuál sería el impacto de un incidente.
- Cuáles son las amenazas.

Por lo tanto, es necesario establecer una política de seguridad.

Identificar las amenazas que acechan a una Organización concreta puede ser una tarea ardua.

Una posible clasificación de amenazas se puede realizar en función del atacante:

- **No estructuradas:**

Suelen realizarse por personas inexpertas que usan herramientas automáticas.

- **Estructuradas:**

Suelen llevarse a cabo por personas motivadas y técnicamente competentes con un objetivo concreto.



Puntos débiles



Existen multitud de puntos débiles en una Organización.

Algunos son implícitos de la tecnología utilizada y otros son atribuibles a las personas.

Entre los más significativos se encuentran los siguientes:

- **Protocolos.**

Todas las capas de TCP/IP presentan de forma implícita puntos débiles.

- Ausencia de autenticación (SNMP).
- Intercambio de datos no cifrados:
 - » HTTP.
 - » Telnet.
 - » FTP.

Aún se siguen utilizando protocolos inseguros, a pesar de que algunos protocolos han evolucionado y otros presentan alternativas seguras:

- SNMP ha evolucionado. SNMPv3 incorpora seguridad.
- HTTP → Se puede usar HTTPS.
- FTP → Se puede usar SFTP.
- Telnet → Se puede usar SSH.

- **Sistemas.**

Tanto los servidores como la electrónica de red pueden presentar servicios instalados por defecto o mal configurados o bugs en aplicaciones o en el propio sistema operativo.

Es importante aplicar salvaguardas en todos los elementos tecnológicos significativos para la Organización.



- **Seguridad física.**

En ocasiones se producen debilidades dentro de las Organizaciones en ámbitos como:

- El control de acceso a ubicaciones.
- La protección de la información en formato físico:
 - » Documentos.
 - » Soportes tipo DVD o pendrive.
- La seguridad operativa en las instalaciones:
 - » Mesas limpias.
 - » Bloqueos automáticos de sesión.

- **Personas.**

Las personas suelen ser el eslabón más débil de la cadena.

Pueden ser objetos de ataques de ingeniería social o *phishing*.

4.1. Componentes de la seguridad perimetral



Fuente: *police-officers-old-playmobil-green-thumbnail* de Piquesels

Vamos a ver los elementos tecnológicos intervinientes en la seguridad perimetral.

- Enrutadores y reglas de filtrado.
- Cortafuegos.
- Sistemas VPN (Tecnologías de redes privadas virtuales).
- Dispositivos de Red.
- Servidores.
- Sistemas de Usuarios y Sistemas Móviles.



4.1.1. Enrutadores y reglas de filtrado

Los enrutadores son dispositivos que permiten a los paquetes de red encontrar el camino adecuado para llegar a su destino.

Para ello utilizan la información del estado de las rutas en cada momento.

Los enrutadores son elementos fundamentales en la seguridad perimetral.

Los enrutadores actuales pueden realizar tareas de cortafuegos.

Es buena práctica que realicen alguna de esas funciones (como filtrado simple de tráfico) siempre y cuando no lo sobrecarguen y perjudiquen su principal función: enrutar los paquetes eficientemente.

A la hora de proteger la red es imprescindible conocer su tipología:

- Protocolos autorizados.
- Rangos de direccionamiento permitidos.
- Etc.

Hay dos estrategias fundamentales para proteger la red utilizando enrutadores:

- **Filtrado.**

Consiste en permitir o denegar el tráfico. Puede utilizar:

- Listas de control de acceso (ACL) (es lo más común).
- Filtrado de camino inverso (Reverse Path Filtering o RPF).
- Rutas de descarte (null routes).

- **Conformado/Limitado.**

Mecanismos de calidad de servicio consistentes en la definición de umbrales de tolerancia al partir de los cuales se aplican medidas sobre el tráfico.

A la hora de aplicar restricciones de filtrado en un enrutador (o en un cortafuegos) deben considerarse, al menos, los siguientes aspectos:

- Denegar la entrada y salida a Internet de direcciones de uso especial:
 - RFC 1918 (*private*).
 - RFC 3330 (*special use*).



- Denegar la entrada y salida de tráfico originado por espacio de direcciones válido, pero no utilizadas (unallocated).
- Denegar la entrada de tráfico con direcciones propias y la salida de tráfico no originado con direcciones propias.
- Denegar el tráfico que incluye violaciones del estándar correspondiente en cada caso.
- Permitir explícitamente el tráfico de retorno hacia las direcciones propias y el tráfico de salida originado con las direcciones propias.
- Permitir el tráfico de los protocolos de enrutamiento y de red estrictamente necesarios, bloqueando otros protocolos y alertando ante el uso de protocolos o servicios especialmente anómalos, como gopher, finger o NetBus.

Por último, es muy importante mantener el dispositivo debidamente actualizado y configurado, y realizar inspecciones de seguridad periódicas sobre los enrutadores corporativos, en especial los perimetrales.

4.1.2. Cortafuegos

Un cortafuegos (*firewall*), es un sistema formado por aplicaciones, dispositivos o una combinación de éstos.

Se encarga de hacer cumplir una política de control de acceso en las comunicaciones entre zonas de red según los criterios establecidos en la política de seguridad.

Por políticas de control de acceso se entienden las primitivas de "permitir" o "denegar" a determinados clientes el acceso a los recursos de red, expuestos como servicios, según unos privilegios de autorización.

Habitualmente estos privilegios a los recursos u objetos se definen mediante listas con entradas secuenciales llamadas juegos de reglas (*rulesets*).

A sus capacidades tradicionales de control de tráfico de red se han añadido multitud de funcionalidades que le permiten llevar a cabo control de acceso, filtrado de contenidos o redes privadas virtuales.

También se han añadido funcionalidades no relacionadas con la seguridad como traducción de direcciones o balanceo de carga.

Se pueden encontrar multitud de tipos de cortafuegos según:

- Ámbito:
 - Cortafuegos de red.
 - Cortafuegos de sistema.



- Función.
- Nivel de actuación en la torre de protocolos.
- Inteligencia en la inspección del tráfico.
- Etc.

Además, pueden tener servicios o funcionalidades añadidas como:

- Traducción de direcciones.
- Redes privadas virtuales.
- Integración de mecanismos de autenticación.

Los cortafuegos deben proporcionar trazas de registro (logs) lo más completas posible para realizar auditorías.

4.1.2.1. Cortafuegos industriales

Los cortafuegos industriales han de permitir la implementación de ciertas características que los diferencien de sus análogos de propósito general, haciéndolos más adecuados para su despliegue en las redes industriales y aportando una capa de seguridad extra para este entorno.

Algunas de estas características principales y ventajas que aportarán gran valor en la segmentación, segregación y control de las redes son:

- **Funcionamiento en modo transparente.**

Un cortafuegos funcionando en modo transparente permite realizar un enrutado de los paquetes, pero sin afectar a la infraestructura, ni requerir de modificaciones de configuración en los dispositivos.

- **Inspección profunda de paquetes (DPI) sobre los protocolos típicos de estos entornos (IEC104, Modbus, DNP3, etc.)**
- **Diseño ruggedizado/industrializado.**

Para soportar ambientes adversos en los que operan las redes industriales.

- **Soporte frente a un volumen elevado de tráfico.**

La llegada de la industria 4.0, hace que el volumen del tráfico intercambiado en una red industrial aumente a la par que aumenta su capacidad de cómputo o la inteligencia proporcionada al proceso.



- **El modo test o de pruebas.**

Es otra de las características de estos cortafuegos. Este modo permite que sean configurados de forma que no afecten a las comunicaciones, pero sí guarden sus acciones en un log, pudiendo así afinar su configuración de la manera menos intrusiva posible y sin provocar ningún problema en la operatividad de los dispositivos bajo su efecto.

- **Inserción VLAN.**

La inserción VLAN es una capacidad de la que disponen los nuevos cortafuegos para poder analizar más cantidad de tráfico.

4.1.2.2. Evolución de los Cortafuegos

Existen varias generaciones de cortafuegos:

- **Packet Filter** (primera generación).

Se lleva a cabo un filtrado basado en:

- Información de red (direcciones IP origen y destino).
- Información de transporte (puertos TCP/UDP y flags de las cabeceras).

- **Application Layer Gateway** (segunda generación).

Se realiza un filtrado a nivel de aplicación, lo que implica una total dependencia del protocolo.

- **Stateful Inspection** (tercera generación).

Se procede a filtrar el acceso usando información existente entre las capas de red y de aplicación, manteniendo información de los flujos de tráfico en una tabla de estado.

- **Unified Threat Management** (UTM o gestión unificada de amenazas).

Es un dispositivo de seguridad que proporciona diferentes soluciones integradas de seguridad perimetral. Esta es la tendencia actual.

Además de las tareas propias de filtrado de un cortafuegos también llevan a cabo:

- Funciones de VPN.
- Antispam.
- Antiphishing.
- Antispyware.



- Filtro de contenidos.
- Antivirus.
- Detección y prevención de intrusiones (IDS/IPS).



+ Info

Consulta la información indicada por el organismo CCN:

CCN-STIC-408: Seguridad Perimetral (Cortafuegos).

4.1.3. Sistemas VPN

Cada vez es más habitual que las organizaciones permitan a su personal la conexión remota a su infraestructura TI a través de Internet.

Por lo tanto, es necesaria una vía de conexión segura a la Organización.

Para proporcionar esta conexión segura se dispone de tecnologías de redes privadas virtuales (VPN, Virtual Private Network).

Proporcionan una capa de abstracción entre la Organización y la conexión del usuario tunelizando la conexión y aplicando una capa cifrada para garantizar la seguridad de la información transmitida.

Más adelante veremos las Redes VPN con más detalle en esta unidad didáctica.

4.1.4. Dispositivos de red

La interconexión de los distintos elementos de la seguridad perimetral entre sí y con las distintas subredes de una Organización se realiza a través de dispositivos de red, habitualmente switches.

No deben utilizarse *hubs*, ya que introduce nuevos riesgos.

Muchos switches tienen problemas y son susceptibles de errores de configuración.



Estos permitirían a un atacante que ha comprometido un sistema conectado al *switch* atacar al mismo *switch* o a los sistemas conectados a él.

Los *switches* se suelen emplear para crear redes locales virtuales (VLAN o *Virtual Local Area Network*).

Esto nos sirve para separar partes de la red en distintos segmentos que tengan distintos requisitos de seguridad.

Las VLANs no fueron creadas por temas de seguridad, sino para limitar el efecto del tráfico de *broadcast* y *multicast* en redes grandes.

Se han revelado diversas vulnerabilidades que permiten introducir tráfico de forma no autorizada desde una VLAN a otra distinta (salto de VLAN o *VLAN Hopping*).

Los *switches* de gama alta disponen de medidas de seguridad para detectar y mitigar ataques a nivel del enlace de datos.

Los *switches* desempeñan un papel fundamental en la gestión de VLANs al segmentar el tráfico de red y permitir una administración eficiente. Su uso permite la implementación de redes más seguras y organizadas, ya que separan los dispositivos en distintos dominios de difusión.

Configuración de VLANs en redes empresariales.

En entornos empresariales, las VLANs permiten gestionar de manera eficiente el tráfico entre departamentos sin la necesidad de múltiples redes físicas. Para permitir la comunicación entre diferentes VLANs, se debe emplear un router o un switch de capa 3, que realiza la interconexión entre las distintas VLANs configuradas.

Tipos de puertos en switches VLAN.

- Puertos de acceso: Usados para conectar dispositivos finales a una VLAN específica.
- Puertos troncales: Utilizados para transportar tráfico de múltiples VLANs entre switches.

Problemas comunes y soluciones.

- Un puerto no tiene acceso a la VLAN esperada porque el puerto no está asignado correctamente a la VLAN. Hay que verificar la configuración con ***show vlan brief*** y corregirla con ***switchport access vlan <id>***.
- Un host no puede comunicarse con dispositivos en la misma VLAN porque su configuración es incorrecta del puerto o por bloqueo por seguridad. Hay que revisar la configuración con ***show interfaces switchport*** y corregir asignaciones erróneas.
- Configuración de NAT en la salida a Internet interfiere con el tráfico VLAN porque NAT está modificando los paquetes de datos, impidiendo su correcta transmisión. Hay que ajustar las reglas de NAT o configurar correctamente el firewall para permitir tráfico de VLANs.



4.1.5. Servidores

Los servidores son los elementos encargados de ofrecer servicios (a la organización o al público en general).

Dado que para ofrecer un servicio hay que proporcionar acceso de una u otra forma a programas corriendo en el sistema.

Estos servicios introducen un riesgo para el propio servidor.

Sin embargo, a través del servidor, también traslada este riesgo a los sistemas y dispositivos de su entorno.

No todos los servicios introducen el mismo riesgo de seguridad.

Los que más peligro afrontan son los que interactúan con entornos hostiles como internet.

Igualmente, hay que tener en cuenta la criticidad de los servicios que ofrecen.

Algunos servicios críticos son:

- Los servicios de nombres (DNS).
- Los servicios de tiempos (NTP).
- Los servicios de correo electrónico (SMTP).
- Los servicios web corporativos.

Para contar con una seguridad perimetral robusta habrá que asegurar debidamente a los servidores.

Para ello será imprescindible aplicar procedimientos de buenas prácticas de instalación y configuración, mantenimiento y operación.

Los sistemas operativos y las aplicaciones actuales cuentan con mecanismos de seguridad que pueden ser configurados para mitigar el riesgo, sumándose así a las medidas de seguridad perimetral desplegadas.

Se pueden realizar varias acciones, que vamos a ver definir, como son:

- Herramientas de software de control de seguridad.
- Instalación de un firewall o proxy.
- WEB APPLICATION FIREWALL.
- DATABASE FIREWALL.



Herramientas de software de control de seguridad

Para que tengamos una mejor perspectiva de ello, vamos a ver las características de la herramienta **Suricata**, que es una de las más completas de la red:

- **Es una de las herramientas de control de seguridad para servidores.**
- Es **gratuita** y de **código abierto**.
- Ofrece a los usuarios un sistema de detección y prevención de intrusos y un completo monitor de seguridad para cualquier servidor conectado a la red, de manera que gracias a él podamos mantener la seguridad de nuestro servidor o dispositivo conectado a la red lo más seguro posible frente a amenazas comunes.

- **Es una herramienta escalable.**

Este monitor de seguridad hace uso de las funciones multi-hilo de manera que solo con ejecutarse en una instancia el monitor balanceará su carga entre todos los procesadores disponibles, evitando incluso alguno de ellos si así lo especificamos. Gracias a ello, esta herramienta es capaz de procesar un ancho de banda de hasta 10 gigabits por segundo sin que ello repercuta sobre el rendimiento.

- **Es capaz de identificar los principales protocolos de red**, siendo capaz de controlar en todo momento todo el tráfico que se genera en el sistema y controlando posibles amenazas de malware.
- También **controla los archivos que viajan por la red**, siendo capaz de identificar un gran número de formatos diferentes, así como realizar comprobaciones MD5 para comprobar que no ha sido modificado y también es capaz de extraer temporalmente ciertos archivos para identificar posible malware escondido.

Instalación de un firewall o proxy

Otra medida adicional es la instalación de un firewall o proxy dedicado en el equipo final, el cual únicamente analizará un tipo de tráfico específico, aportando una capa más de seguridad al servidor y por tanto a su entorno.

Tipos de proxys más comunes.

- **Proxy web:**

Sin duda uno de los servidores proxy más populares son los webs.

Estamos ante una opción en la que los usuarios pueden acceder a través de una página web. Esa web es la que actúa como proxy. Está basado en HTTP y HTTPS y actúa como intermediario para acceder a otros servicios en Internet.

A través de esa página web podremos navegar por otros sitios. Toda esa navegación pasa a través del proxy web que estamos utilizando.



- **Proxy caché:**

Otra opción es la de un servidor proxy caché. En este caso este servidor actúa como intermediario entre la red e Internet para cachear contenido. Puede ser contenido de tipo estático como HTML, CSS, imágenes... Se utiliza para acelerar el contenido de un sitio al navegar.

Si una persona entra en una página por segunda vez, esa información que está cargando ya puede estar cacheada. De esta forma no necesita descargarla de nuevo y va más rápido.

Si queremos que nuestro proxy-caché acepte protocolos HTTP, HTTP/2, HTTPS podemos encontrar distintas soluciones como **Squid, Apache Traffic Server, Varnish, Nginx, HAProxy**.

- **Proxy inverso:**

Un proxy inverso se sitúa entre un grupo de servidores y los clientes que desean utilizarlos, de esta forma la petición del cliente verá como una sola unidad al equipo de servidores, encargándose el proxy de dirigir la petición al servidor correspondiente.

Se utiliza generalmente para controlar el tráfico entrante hacia una o varias aplicaciones o servidores web. Optimiza y protege los servidores internos facilitando balanceo de carga, ocultamiento de infraestructura de red y manejo de caché.

- **Proxy transparente:**

En este caso lo que hace el proxy es obtener la petición que hemos dado y darle una redirección sin necesidad de modificar nada previamente ni de hacer una configuración específica. Se ubica normalmente dentro de la red interna de una organización. Intercepta y redirige el tráfico de manera automática sin requerir ninguna configuración adicional en los clientes.

Se usa generalmente para controlar el tráfico saliente desde la red interna hacia la externa, filtrar contenido, controlar el ancho de banda y mejorar la seguridad.

- **Proxy NAT:**

Una opción más en cuanto a proxys son los proxy NAT.

Principalmente se utilizan para enmascarar la identidad de los usuarios. Esconde la verdadera dirección IP para acceder a la red. Cuenta con variadas configuraciones.

WEB APPLICATION FIREWALL (WAF)

Los WAF (Web Application Firewalls) son sistemas de protección de tráfico web, con una base de datos de firmas de las distintas vulnerabilidades existentes, capaces de analizar el comportamiento del usuario y detectar:

- Manipulación de parámetros en cabeceras o cookies.
- Inyecciones SQL.
- Ataques de Cross-site Scripting (XSS).



Puede bloquear el tráfico anómalo detectado.

En un cluster de Firewalls se puede implementar un módulo de seguridad de este tipo con el fin de filtrar y monitorear el tráfico HTTP proveniente de Internet a nuestros servidores WEB. El WAF es un sistema frecuentemente usado para identificar y bloqueando amenazas dirigidas a aplicaciones web.

DATABASE FIREWALL

Los firewalls de base de datos son sistemas dedicados que se instalan como front-end de los servidores finales.

analizan exclusivamente el tráfico SQL, detectando posibles alteraciones y haciendo cumplir la política de acceso.

4.1.6. Sistemas de Usuario y Sistemas Móviles

Estos sistemas de usuario necesitan formar parte de las estrategias de seguridad perimetral debido a que hay muchos ataques que explotan sus vulnerabilidades.

La mejor forma de prevenir estas amenazas es manteniendo actualizado el sistema operativo y las aplicaciones, instalando *software* antivirus y formando a los usuarios en seguridad.

Dentro de los sistemas de usuario merecen una mención especial los sistemas móviles, tales como portátiles, smartphones, tabletas, etc.

Cuando a dichos sistemas se les permite acceso a la Organización desde fuera de la misma están extendiendo de forma natural su perímetro, por lo que es necesario controlar especialmente todos los elementos que introduzcan movilidad en la información corporativa.



El experto opina

El acceso desde el exterior a los recursos internos de la organización debería realizarse siempre a través de VPN.

Tecnologías inalámbricas

La introducción masiva de tecnologías inalámbricas, en especial WiFi, ha propiciado la paulatina disolución del perímetro físico de la Organización.

Ya no es necesario un acceso físico al interior de la organización.



Es suficiente con situarse dentro del alcance de los dispositivos inalámbricos.

A pesar de que estas tecnologías han ido incluyendo mejoras en el ámbito de la seguridad, lo cierto es que hasta el momento ninguna de ellas ha satisfecho plenamente los requisitos necesarios para asegurar una adecuada protección en términos de confidencialidad, disponibilidad, integridad y autenticación de la información manejada.

Recordemos conceptos muy importantes:

- **Confidencialidad:**

Es la propiedad que impide la divulgación de información a individuos, entidades o procesos no autorizados. A grandes rasgos, asegura el acceso a la información únicamente a aquellas personas que cuenten con la debida autorización.

La pérdida de la confidencialidad de la información puede adoptar muchas formas.

Cuando alguien mira por encima de su hombro, mientras usted tiene información confidencial en la pantalla, cuando se publica información privada, cuando un laptop con información sensible sobre una empresa es robado, cuando se divulga información confidencial a través del teléfono, etc.

Todos estos casos pueden constituir una violación de la confidencialidad.

- **Integridad:**

Es la propiedad que busca mantener los datos libres de modificaciones no autorizadas. (No es igual a integridad referencial en bases de datos.)

A grandes rasgos, la integridad es mantener con exactitud la información tal cual fue generada, sin ser manipulada ni alterada por personas o procesos no autorizados.

La integridad también es la propiedad que busca proteger que se modifiquen los datos libres de forma no autorizada, para salvaguardar la precisión y completitud de los recursos.

La violación de integridad se presenta cuando un empleado, programa o proceso (por accidente o con mala intención) modifica o borra datos importantes que son parte de la información.

- **Disponibilidad:**

La disponibilidad es la característica, cualidad o condición de la información de encontrarse a disposición de quienes deben acceder a ella, ya sean personas, procesos o aplicaciones.

La alta disponibilidad de sistemas debe estar disponible en todo momento, evitando interrupciones del servicio debido a cortes de energía, fallos de hardware, y actualizaciones del sistema.

Garantizar la disponibilidad implica también la prevención de ataque de denegación de servicio.



Para poder manejar con mayor facilidad la seguridad de la información, las empresas o negocios se pueden ayudar con un sistema de gestión que permita conocer, administrar y minimizar los posibles riesgos que atenten contra la seguridad de la información del negocio.

- **Autenticación:**

Es la propiedad que permite identificar el generador de la información. Por ejemplo, al recibir un mensaje de alguien, estar seguro que es de ese alguien el que lo ha mandado, y no una tercera persona haciéndose pasar por la otra (suplantación de identidad).

Diversos problemas permiten romper el perímetro, evitando cortafuegos o enrutadores y burlando la detección de intrusos.

Si implementamos una red WiFi debemos poner en marcha medidas como:

- El control de acceso, la regeneración de claves vía TKIP.
- El cifrado robusto mediante el uso de AES.

Por otra parte, debemos evitar protocolos como WEP o WPA que ya han demostrado ser vulnerables.

Una configuración adecuada de estos parámetros hará mucho más compleja la tarea de penetrar en el perímetro a partir de la infraestructura inalámbrica.

En el caso de los dispositivos que hacen uso de la tecnología Bluetooth, el tipo de vulnerabilidades detectadas y su alcance (pocos metros) no suele suponer un problema.

Otro riesgo que considerar es el uso de Smartphone que incorporan conexión WiFi y 3G o 4G.

Aunque habitualmente en la mayor parte de modelos no se permite el uso simultáneo de ambos interfaces de comunicación, un usuario malintencionado podría alterar este comportamiento, lo que podría propiciar que en un momento determinado se puentee la red corporativa directamente a Internet a través de estos dispositivos, sin pasar por un cortafuegos, con los evidentes riesgos de seguridad que esto implica para la Organización.

Es por tanto obligatorio establecer controles de seguridad en la conexión de estos dispositivos a la red de la Organización.

4.2. Esquema de arquitectura de red

Uno de los aspectos básicos de la seguridad en la red es su arquitectura.

En el diseño de la arquitectura de red utilizamos determinados componentes que nos permitan canalizar, permitir o restringir el tráfico de la información.

Hay tres elementos básicos para aumentar la seguridad:

- **Uso de Enrutadores.**

Conecta dos o más redes y permite o deniega la comunicación entre redes.



- **División de la red interna.**

Para aumentar la seguridad se puede dividir la red interna en varias redes para controlar (permitir o denegar) el tráfico entre ellas.

- **Establecer una zona (o varias) desmilitarizada (Protección perimetral).**

Consiste en establecer una zona entre la red interna e internet.

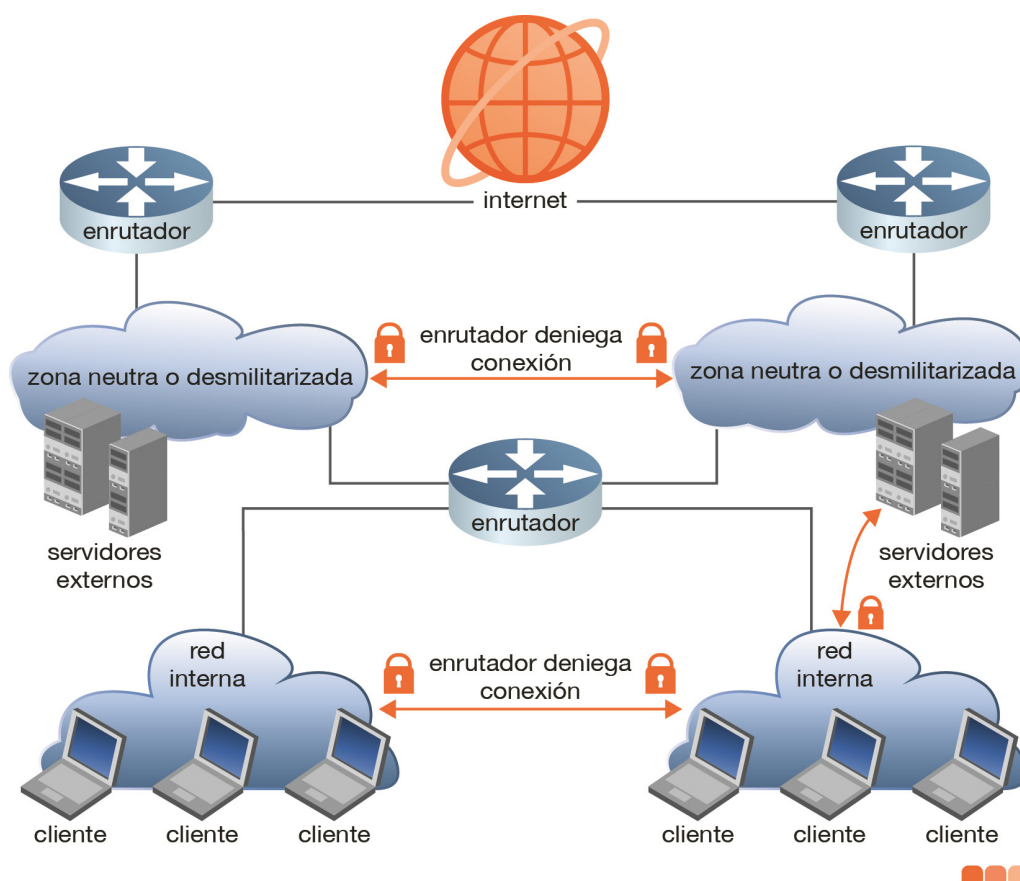
Aquí se situarán los servidores, los cuales necesitan poder enviar y recibir datos a internet, por lo que son más vulnerables.

Sin embargo, no se admite la comunicación desde esta zona hacia la red interna.

De esta forma, si hay una intrusión en uno de los servidores, la red interna estará aislada y no se le permitirá el acceso al intruso.

En caso de tener varios servidores con distintas funciones, podemos separarlos también en distintas zonas desmilitarizadas para aislar unos de otros.

A continuación, mostramos un gráfico donde podrás ver cómo se han aplicado todas estas medidas de seguridad. Por norma general, las medidas utilizadas dependerán de las necesidades y el coste.





4.3. Sistemas de protección de las comunicaciones

En una red, se pueden intentar accesos que pueden ser:

- Ataques esporádicos realizados por usuarios malintencionados.
- Ataques repetidos cada cierto tiempo, lanzados con herramientas automáticas.

Existen herramientas de software, que tienen un papel importante para la ciberseguridad de la empresa, realizando las tareas de monitorizar el tráfico que entra y/o sale de nuestra red y detectar intrusiones.

Podemos clasificarlas en tres tipos, con diferentes características:

- Sistema de detección de intrusiones (**IDS**).
- Sistema de prevención de intrusiones (**IPS**).
- Sistema de gestión de eventos e información de seguridad (**SIEM**).



+ Info

También puedes consultar en Internet diferentes productos de hardware en el mercado.

https://www.incibe.es/protege-tu-empresa/catalogo-de-ciberseguridad/buscador-soluciones?combine=intrusiones&term_node_tid_depth_join=357&field_sol_dimension_tid=All&field_sol_empresa_target_id=All&field_sol_gratuito_value=All&submit=Buscar

4.3.1. Sistema de Detección de Intrusiones (IDS)

Se denomina intrusión a un conjunto de acciones que intentan comprometer la integridad, confidencialidad o disponibilidad de la información o de los entornos que la manejan.

Un IDS, (Intrusion Detection System) o sistema de detección de intrusiones es una aplicación usada para detectar accesos no autorizados a un ordenador o a una red. Coloquialmente también se conoce como sistemas de detección de intrusos.



Los sistemas de detección de intrusos tienen por objeto detectar ataques desde la Organización (extrusiones), hacia la Organización (intrusiones) o en la propia Organización.

Monitorizan el tráfico entrante y lo cotejan con una base de datos actualizada de firmas de ataque conocidas, y si detectan una actividad sospechosa, emiten una alerta al administrador de red (o de sistema) que deberá tomar las medidas necesarias. Únicamente detectan accesos sospechosos pero no tratan de mitigar la posible intrusión (Su actuación es reactiva).

En este sentido es obligatorio el análisis y despliegue de entornos que permitan esta detección, con el objetivo de poder responder a situaciones de riesgo en el menor tiempo posible.

Para conseguir sus objetivos, un IDS debe cumplir los siguientes requisitos:

- Debe ejecutarse continuamente sin supervisión humana.
- Debe ser aceptable en el entorno:
 - Permitiendo el correcto funcionamiento del resto de sistemas.
 - Generando información útil y que permita su gestión eficiente.
- Minimizar las tasas de falsos positivos y negativos:

Las tasas de falsos positivos (detecciones que realmente no se corresponden con una intrusión) y de falsos negativos (intrusiones no detectadas por el sistema) deben ser mínimas.

- Debe ser adaptable al entorno de trabajo:

Esto incluye la tolerancia a fallos o a situaciones anómalas.

4.3.1.1. Clasificación

En la actualidad existen distintos tipos de software de detección de intrusiones.

Históricamente, los sistemas de detección de intrusos se clasificaron de dos formas:

- **Un IDS pasivo.**

Detectara actividad maliciosa, y genera alertas o entradas de registro, pero no tomar medidas.

- **Un IDS activo.**

Denominado a veces sistema de detección y prevención de intrusos (IDPS), ya que generaría alertas y entradas de registro, y también podría estar configurado para tomar medidas como bloquear direcciones IP o cerrar el acceso a recursos restringidos.



También existen diferentes enfoques a la hora de clasificarlos, que vamos a ver con más detenimiento:

- **En función de qué sistemas monitorizan.**
 - IDS **basado en red** (NIDS o *Network based IDS*).
 - IDS **basado en host** (HIDS o *Host based IDS*).
 - » **Los verificadores de integridad del sistema** (SIV o *System Integrity Verifiers*).
 - » **Los monitores de registros** (LFM o *Log File Monitor*).
 - » **Los honeypots** o tarros de miel, también llamados sistemas de engaño.
- **En función de cómo lo hacen.**
 - Basadas en la **detección de anomalías** (anomaly detection).
 - Basadas en la **detección de usos indebidos** (misuse detection).

4.3.1.1.1. En función de qué sistemas monitorizan

Según los sistemas que monitorizan se pueden establecer dos grandes grupos:

- IDS **basado en red** (NIDS o *Network based IDS*).

Monitoriza los paquetes que circulan por la red en busca de elementos que denoten un ataque contra alguno de los sistemas ubicados en ella.

El IDS puede situarse en cualquiera de los hosts o en un elemento que analice todo el tráfico, como un switch o un enrutador.

Esté donde esté, monitorizará diversas máquinas y no una sola.

- IDS **Basado en host** (HIDS o *Host based IDS*).

Realizan su función protegiendo un único sistema.

El IDS busca patrones que puedan denotar una intrusión y alerta o toma las medidas oportunas en caso de que uno de estos patrones sea detectado.

Dentro de esta categoría se suelen diferenciar:

- **Los verificadores de integridad del sistema** (SIV o *System Integrity Verifiers*).

Monitorizan archivos de un Sistema en busca de posibles modificaciones no autorizadas.



- **Los monitores de registros** (LFM o *Log File Monitor*).

Vigilan archivos de log en busca de patrones que puedan indicar una situación anómala.

- Los **honeypots**, tarros de miel o sistemas de engaño son mecanismos encargados de simular objetos (servicios, ficheros, aplicaciones...) con problemas de seguridad de forma que un atacante piense que puede aprovechar el incidente en beneficio propio, cuando realmente se está utilizando para registrar todas sus actividades.

4.3.1.1.2. En función de cómo lo hacen

Según cómo operan estos sistemas vamos a indicar dos grandes técnicas:

- Basadas en la **detección de anomalías** (anomaly detection).

Se basa en la suposición de que una intrusión se puede considerar una anomalía del entorno.

Se establece un perfil del comportamiento habitual que permitirá detectar las intrusiones por estadística.

Se crea un modelo predictivo o una función que permite identificar la normalidad y la anormalidad.

- Basadas en la **detección de usos indebidos** (misuse detection).

Presupone que es posible establecer patrones para los diferentes ataques conocidos y algunas de sus variaciones, identificándolos de forma directa.

4.3.1.2. Tipos de software de detección de intrusiones

Actualmente existen distintos tipos de software de detección de intrusiones, según el sistema de operar que utilizan:

- **Sistema de detección de intrusiones en la red (NIDS):**

Normalmente se implementa en puntos estratégicos de la red, para cubrir lugares donde el tráfico es más vulnerable a los ataques, examina pasivamente el tráfico de red, suele aplicarse a subredes completas e intenta hacer coincidir el tráfico que pasa con una biblioteca de ataques conocidos.

Como analiza una gran cantidad de tráfico de red, a veces tienen poca especificidad, pudiendo no detectar un ataque o algo que sucede en el tráfico encriptado. Esto hace que pueda necesitar que el administrador se asegure de que esté configurado correctamente.

Uno de los NIDS más utilizados para detectar amenazas emergentes, es Snort, de código abierto, de libre acceso y ligero. Puede compilarse en la mayoría de los sistemas operativos Unix o Linux, y también tiene disponible una versión para Windows.



- **Sistema de detección de intrusos (HIDS):**

Se ejecuta en todos los dispositivos en la red con acceso a Internet o a la red interna de la empresa.

Un HIDS puede identificar tráfico malicioso que se origina en el propio host, (como cuando el host ha sido infectado con malware y está intentando propagarse a otros sistemas), y puede detectar paquetes de red anómalos que se originan dentro de la organización o tráfico malicioso que un NIDS no ha podido detectar.

- **Sistema de detección de intrusos basado en firmas (SIDS):**

Funciona de forma similar a los antivirus, que disponen de una base de datos de virus conocidos.

Un SIDS monitoriza todos los paquetes que atraviesan la red y los compara con una base de datos de firmas de ataque o atributos de amenazas maliciosas conocidas, (igual que el software antivirus).

El inconveniente de este método, es que necesita que las firmas se actualicen, de forma que cuando hay un nuevo método de ataque, debe ser agregado a la base de datos lo antes posible para poder ser detectado (igual que un virus nuevo en cualquier software antivirus).

Hay un retraso entre la aparición del nuevo tipo de ataque, y la actualización de las firmas de ataque, por ello es importante al elegir un proveedor, que sea rápido en proporcionar firmas de ataque actualizadas.

- **Sistema de detección de intrusos basado en anomalías (SIDA):**

Monitoriza el tráfico de la red y lo compara con una línea de base establecida para determinar lo que se considera tráfico normal para la red, con respecto al ancho de banda, puertos, protocolos y otros dispositivos.

Normalmente un SIDA utiliza el aprendizaje automático, y mejora las limitaciones de los métodos basados en firmas, cuando aparecen nuevas amenazas.

4.3.2. Sistema de Prevención de Intrusiones (IPS)

IPS, (Intrusion Prevention System) o sistema de prevención de intrusiones, es un software que se utiliza para proteger a los sistemas de ataques e intrusiones.

Su actuación es preventiva, realizando un análisis en tiempo real de las conexiones y los protocolos para determinar si se está produciendo o se va a producir un incidente. Para ello identifica ataques según patrones, anomalías o comportamientos sospechosos y permite el control de acceso a la red, implementando políticas basadas en el contenido del tráfico monitorizado.

Por tanto, el IPS lanza alarmas, y también puede descartar paquetes y desconectar conexiones.



Los proveedores normalmente suelen ofrecer productos mixtos, denominándolos IPS/IDS, que se integran también con cortafuegos y UTM para controlar el acceso en función de reglas sobre protocolos y sobre el destino u origen del tráfico.

Los IPS se consideran como una extensión de los IDS por estar muy relacionados con ellos.

4.3.2.1. Tipos de IPS

Existen 4 tipos de IPS que veremos a continuación con más detalle:

- HIPS (Host IPS).
- NIPS.
- NBA (Network Behavior Analysis).
- WIPS (Wireless Intrusion Prevention System).

4.3.2.1.1. HIPS (Host IPS)

Su tarea es buscar actividades sospechosas en host únicos.

HIPS monitorea la actividad del sistema y emplea un conjunto de reglas predefinidas con el fin de reconocer un comportamiento sospechoso del sistema.

(HIPS se encuentra incluido en ESET NOD32 Antivirus y ESET Smart Security 5).

4.3.2.1.2. NIPS (Network-based Intrusion Prevention System)

Traducido como "Sistema de prevención de intrusiones basado en red", este sistema monitorea la red en busca de actividad maliciosa o tráfico sospechoso mediante el análisis de la actividad del protocolo.

Cuando NIPS se instala en una red, se utiliza para crear zonas de seguridad física, lo que provoca que la red sea inteligente y distinga rápidamente el buen tráfico del mal tráfico, como si se convirtiera en una prisión para todo el tráfico hostil, como gusanos, troyanos, virus y amenazas polimórficas.

Busca tráfico de red sospechoso, para proteger la confidencialidad, integridad y disponibilidad de la misma, siendo sus funciones principales proteger la red de amenazas, (como la denegación de servicio (DoS)) y el uso no autorizado.



+ Info

Se llama malware polimórfico al malware que tiene código polimórfico.

El polimorfismo previene la detección e identificación del malware mediante mecanismos de ajuste de patrones, consigue que el malware no tenga una manifestación constante, (ya sea en almacenamiento o en memoria).

El polimorfismo varía la apariencia de las instancias de malware.

4.3.2.1.3. NBA (Network Behavior Analysis)

Traducido como Análisis del Comportamiento de la Red, NBA es un programa de monitoreo de red que garantiza la seguridad de una red propietaria.

Examina el tráfico inusual como ataques de denegación de servicios o violaciones de las políticas de seguridad o ciertas formas de malware.

Es un método de ayuda a mejorar la seguridad de la red, vigilando el tráfico y observando actividades inusuales y salidas de una operación de red, detectando cualquier cosa que se salga de lo habitual, detectando posibles ataques DoS y malwares.



+ Info

NBAD, es la detección de anomalías comportamiento de la red que investiga las tendencias inusuales en el tráfico de la red.

Cuando se detecta una amenaza, NBAD hace seguimiento de las características de la intrusión y suena una alarma si el ataque es considerado como una amenaza (incluyen anomalías de protocolo, la suplantación de MAC, IP spoofing, duplican despliegue en abanico IP, IP, MAC duplicadas y los virus).



4.3.2.1.4. WIPS (Wireless Intrusion Prevention System)

Basados en Wireless, buscan en la red inalámbrica tráfico sospechoso.

Este sistema de seguridad inalámbrica es capaz de diferenciar entre los puntos de acceso legítimos, malintencionados y los cercanos de otras redes que, aunque comparten el mismo espacio, son ajenos a la red wifi que se quiere proteger (las redes wifi cercanas).

WIPS es uno de los elementos imprescindibles para políticas BYOD (Bring Your Own Device).

Indicamos a continuación los principales ataques contra los que nos protege WIPS:

- **Detección y bloqueo de Rogue Access Points (Rogue APs) o Puntos de acceso falsos (Fake APs).**

Se crean puntos de acceso falsos que intentan parecer legítimos.

Es un ataque muy eficaz en sitios con mucha afluencia de gente, con hotspots gratuitos (como aeropuertos, hoteles etc.) Por ejemplo, un hotspots llamado Wifi Hotel, que detectamos en nuestro dispositivo y que en realidad no pertenece al hotel, sino que está controlado por ciberdelincuentes que esperan a que se conecten usuarios incautos.

- **Detección y gestión de APs mal configurados.**

El sistema WIPS detecta los puntos de acceso que han perdido la configuración, tienen claves de acceso por defecto o se han reseteado a sus valores de fábrica, o cuando se ha modificado deliberadamente su configuración convirtiéndolos en vulnerables, y los desautoriza de la red.

- **Cientes mal configurados o atacantes.**

Detecta si hay usuarios cuyos intentos de conexión a la red son denegados de forma repetitiva. Después es necesario saber si se trata de un cliente mal configurado o es un intento de conexión de un atacante.

- **Bloqueo de usuarios no autorizadas.**

Aunque un usuario conozca la contraseña de acceso a la wifi, se le bloquea el acceso.

- **Evil Twins.**

Son puntos de acceso (AP o Access Point) creados malintencionadamente con el objetivo de suplantar a uno legítimo, y poder controlar el tráfico, las comunicaciones, y robar credenciales (contraseñas, datos de las webs que visitamos, imágenes...).

El AP malintencionado (señuelo, o "gemelo malvado") emite una señal más potente que el legítimo, para que el cliente se conecte a él.



Es diferente que Rogue Access Points:

- El Rogue Access Points se basa en engañar con un nombre PARECIDO al real, para que la víctima se conecte a él.
- El Evil Twins, se basa en emitir una señal más potente CON EL MISMO NOMBRE del real, para que la víctima use el falso.

- **AP MAC Spoofing.**

Un ataque muy conocido de los hackers para tener acceso a la red pasando desapercibido, consiste en obtener la MAC de un AP legítimo y realizar una suplantación utilizando esa misma dirección MAC.

- **DoS Spoofed Disconnection.**

Son ataques de denegación de servicio (interrumpiendo el servicio wifi, bloquearlo, colapsarlo...). Se realiza enviando tramas de desconexión a los clientes, impidiendo así que puedan utilizar los puntos de acceso.

- **DoS Flooding.**

El ataque se puede realizar de con diferentes finalidades, como saturar las tablas de enrutamiento de los switches (y así obtener información de las conexiones), hasta inhabilitar los puntos de acceso. Si no se dispone de un WIPS, la única opción posible es reiniciar los equipos.

- **DoS Jamming.**

Se conocen popularmente como jammers o inhibidores, ya que se trata de interferir la frecuencia para impedir el uso de los puntos de acceso.

Un jammer, es un generador de señales que van a interferir una comunicación inalámbrica. Es necesario encontrar la frecuencia adecuada para que el ataque sea efectivo y con la potencia suficiente para suplantar la señal original.

Hay dos tipos de jamming (ataques de interferencia) que se pueden realizar:

- Spot o de forma dirigida, que va direccionado a interferir una frecuencia específica.
- Barrage o múltiple, cuando se trata de afectar varios canales simultáneamente.

- **Cientes puente.**

Se trata de clientes que están correctamente autorizados para utilizar una red, pero que están permitiendo a través de ellos la conexión de otros dispositivos que no están siendo supervisados.

Por ejemplo, un portátil conectado legítimamente, pero que está dando conexión a una Tablet, es decir la Tablet, aunque no tenga permisos, se está conectando a través del portátil.



Es una Identificación y bloqueo de redes "Ad-hoc", ya que en las conexiones "peer-to-peer", los dispositivos se agregan estando en el mismo rango de la red (es el caso de 2 portátiles dentro de una habitación del hotel), representado un riesgo de seguridad.



+ Info

Algunos de los mejores softwares de sistemas de prevención de intrusiones (IPS) son:

- SolarWinds.
- Splunk.
- Sagan.
- Ossec.
- Open WIPS NG (para redes wifi).
- Fail2Ban.
- Bro Network Security Monitor.

4.3.3. Sistema de gestión de eventos e información de seguridad (SIEM)

SIEM (Security Information and Event Management) o sistema de gestión de eventos e información de seguridad, es una solución de tecnología híbrida centralizada que engloba:

- La gestión de información de seguridad (Security Information Management).
- La gestión de eventos (Security Event Manager).

SIEM proporciona:

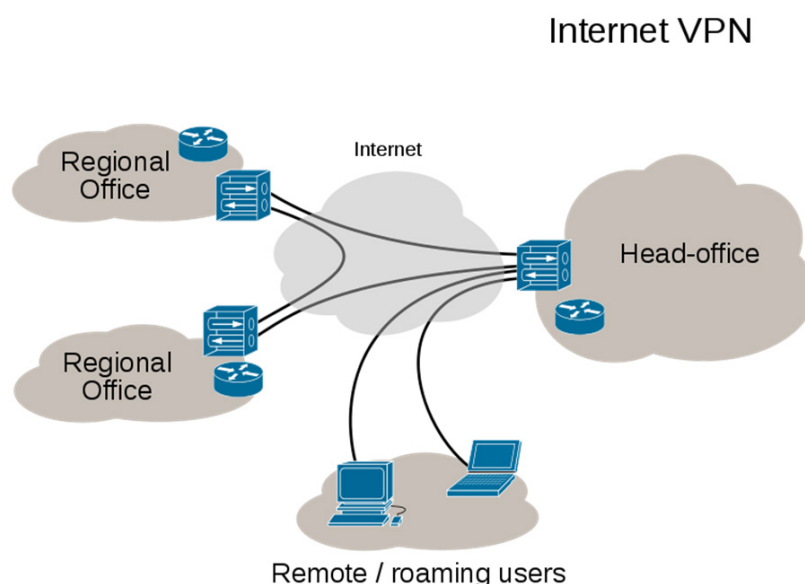
- Un análisis en tiempo real de las alertas de seguridad generadas por los distintos dispositivos hardware y software de la red.
- Recoge los registros de actividad (logs) de los distintos sistemas, los relaciona y detecta eventos de seguridad.



Es decir, detecta actividades inesperadas o sospechosas que pueden suponer el inicio de un incidente, descartando los resultados anómalos, conocidos también como falsos positivos, y genera respuestas acordes, basándose en los informes y evaluaciones que registra continuamente.

Por tanto, podemos indicar que SIEM es una herramienta en la que se centraliza la información y se integra con otras herramientas de detección de amenazas.

5. Redes privadas virtuales (VPN)



Fuente: Ludovic.ferre

(https://commons.wikimedia.org/wiki/File:Virtual_Private_Network_overview.svg)

Una conexión VPN (Virtual Private Network), o red privada virtual, permite crear una red local sin que sus integrantes necesiten estar físicamente conectados entre sí, sino que se conectan utilizando una red pública, normalmente Internet (por ello el termino virtual).

Hemos visto por encima lo que es una VPN desde el punto de vista de la seguridad perimetral, pero ahora vamos a profundizar más en su estudio.

Cuando necesitamos conectarnos a los recursos de la empresa (por ejemplo, si teletrabajamos desde casa) debemos asegurar la confidencialidad e integridad de los datos que estamos transmitiendo. Para ello debemos tomar algunas precauciones para proteger esta información.

Podemos tener muchos problemas al trabajar desde fuera del entorno de trabajo ya que la red de casa no es segura y mucho menos las redes abiertas del tren, bar, hotel, etc. Si trabajas mientras viajas o te tomas un "descanso".



Posiblemente la mejor herramienta de seguridad que podemos implantar para utilizar nuestros dispositivos móviles (teléfono, portátil, etc.) desde fuera de la oficina es utilizar una VPN (Red Privada Virtual o Virtual Private Network).

Las conexiones establecidas utilizando VPN protegen la información que se intercambia estableciendo un «túnel» o canal cifrado de comunicación entre nuestro dispositivo y nuestro lugar de trabajo por donde «viajan» nuestros datos confidenciales de manera segura.

Al conectarnos a una de estas redes, nuestro equipo o dispositivo se conecta virtualmente a nuestra red de trabajo, es decir, que se conecta como si fuera un equipo más de nuestra red de trabajo local, de forma totalmente transparente para el usuario.

VPN es una red privada que utiliza una red pública para conectar sitios o usuarios remotos entre sí.

Una VPN protege las conexiones que se puedan realizar a través de Internet a un equipo, garantizando que la información que se envía y recibe esté codificado, se mantiene la ubicación y tráfico ocultos.

Al utilizar una conexión VPN, todo el tráfico de red (a partir de tu proveedor de Internet) se dirige al servidor VPN, y de ahí partirá al destino final, como la conexión está cifrada, el proveedor de Internet no sabrá a qué se está accediendo, la dirección IP del equipo conectado, es a efectos prácticos la del servidor VPN.

Para implementar una VPN, en función del tipo, hay que incorporar ciertos componentes para generarla, como pueden ser:

- Hardware exclusivo (como un Firewall o un concentrador de VPN).
- Servidor de VPN exclusivo para servicios telefónicos.
- Servidor de acceso a la red (NAS) usado por el proveedor de servicios para el acceso de VPN de usuario remoto.
- Red privada y Centro de administración de políticas.
- Cliente de software de escritorio para cada usuario remoto.

Una VPN bien diseñada utiliza varios métodos para conservar sus datos y la conexión seguros.

Ventajas y desventajas del uso de VPN

Vamos a analizar las VPN en cuanto a sus ventajas y desventajas:

- **Ventajas:**
 - Cifrado de datos y conexión:
Garantiza la seguridad de toda la información que transmitamos.



- Confidencialidad e integridad de la información:

Puesto que la información está cifrada, no puede ser leída, modificada o alterada durante la transmisión.

- Mayor seguridad:

La información se trasmite solo entre dispositivos autorizados y configurados.

- Restricciones de acceso:

Es necesario el acceso a estas redes mediante un usuario y contraseña autorizados.

- Escalabilidad:

El aumento de usuarios que pueden utilizarlo es fácil de realizar y gestionar.

- **Desventajas:**

- Es necesario instalar, configurar y poner en marcha el servicio, lo cual conlleva un coste económico.
- La red de la empresa se debe reestructurar y configurar para poder acceder a ella, lo que implica modificaciones por parte de nuestro servicio o proveedor de comunicaciones.
- Deben configurarse los dispositivos móviles que accedan a la red VPN.

Hay que proporcionar un certificado y un usuario/contraseña de acceso al servicio a los usuarios que la utilicen, e instalar el software necesario en sus dispositivos móviles.

5.1. Posibles usos y característica de las conexiones VPN

En general, este tipo de redes se debe utilizar cuando necesitemos establecer una comunicación confidencial, y la red que estemos utilizando no ofrezca las suficientes garantías de seguridad.

Algunos casos de uso son:

- **Cuando utilicemos redes públicas o no confiables.**

Estas redes (como redes wifi de hoteles, cafeterías, aeropuertos, etc.) pueden ser muy peligrosas para la confidencialidad de nuestros datos, ya que cualquiera que esté conectado a la misma red, puede «espiar» nuestras comunicaciones.

- **Para acceder a los recursos corporativos de la empresa.**
- **Al realizar operaciones confidenciales, como por ejemplo banca online.**



- **Para interconectar redes separadas de forma segura.**

Sedes separadas geográficamente, o equipos utilizados en teletrabajo debe funcionar de forma segura como si fuese la misma red sin tener que contratar una línea de conexión dedicada en exclusiva.

- **Uso para Teletrabajo.**

Para trabajadores que están físicamente fuera de la empresa, y que necesitan acceder a una única red privada, el uso de una conexión VPN, proporciona un acceso protegido, conexión cifrada, dando el mismo acceso que si el trabajador estuviera presencialmente en la empresa.

También de igual modo, para empresas con sucursales en varias ciudades.

- **Fácil conexión y desconexión y funciona en todas las aplicaciones.**

Una vez configurado, puedes activar y desactivar la conexión fácilmente, y puesto que enruta todo el tráfico de Internet, (no como en los servidores proxy) funciona en todas las aplicaciones.

- **Evitar bloqueos y censura de contenido por localización geográfica.**

VPN, también proporciona lo que se conoce como "falsear dónde estás".

Puesto que el usuario se conecta a un VPN, será esta la que proporcione la ubicación física cuando se comunique con Internet, de forma que si el usuario está por ejemplo en China, y el servidor VPN se encuentra en Estados Unidos, la mayoría de servidores web, creerán que accedes desde Estados Unidos, por lo que te proporcionarán acceso a los contenidos disponibles en Estados Unidos (por ejemplo Netflix), y no se bloquearán los contenidos que puedan estar censurados o bloqueados en el país donde el usuario está realmente.

China, en nuestro ejemplo, tiene millones de ciudadanos que logran de esta forma conectarse por ejemplo a Facebook y a otras más de 3.000 webs bloqueada, ya que El firewall de China impide la conexión con Facebook, pero no con un VPN que después conecte con Facebook.

No siempre es posible "falsear dónde estás", especialmente en conexiones con dispositivos móviles donde se puede triangular y aproximar tu ubicación sin tener en cuenta la dirección IP.

- **Seguridad en Conexiones wifi.**

Lo normal es que las conexiones VPN, tengan un cifrado de los paquetes que transmiten, por lo que se suele recomendar que no se realice una conexión a un punto de acceso wifi público sin utilizar una VPN.

Este cifrado evita, por ejemplo, que, si te conectas a tus cuentas bancarias, mediante una red WiFi pública un hacker capture los paquetes sin cifrar y tenga acceso a tus cuentas, mientras que si están cifrados no podrá hacer uso de esa información, no obstante, estas confiando plenamente en el servidor de VPN, que también puede capturar todo tu tráfico, guardar registros de todo lo que realizas por Internet etc., por tanto la seguridad de una VPN, dependerá también del proveedor de Internet que utilices, el proveedor no puede saber qué haces a través de Internet, pero sí podrá saberlo la compañía que gestiona el VPN.



- **Descargas P2P.**

Normalmente, los usuarios utilizan a menudo las descargas P2P de Canciones y álbumes, Audiolibros, Videos musicales o grabaciones de conciertos o actuaciones en directo, así como aplicaciones de música u otros tipos, que suelen ser ilegales, o incluso si se trata de torrents legales, algunos proveedores de internet, en ocasiones bloquean estas descargas, o hacen que funcionen mal para que desistas de hacer dicha descarga (evitando así que haya excesivo tráfico).

Torrent es un formato de archivo que almacena la información que se comparte en la red. Básicamente descargamos un archivo para abrirlo con una aplicación capaz de leer esa información y obtener el contenido. Se utiliza principalmente para compartir archivos de gran tamaño, y también en las comunicaciones de voz, por ejemplo.



+ Info

Usar una VPN no garantiza que la navegación sea anónima.

Según Edward Snowden (estadounidense guardia de seguridad en las instalaciones secretas de la NSA, Agencia Nacional de Seguridad y experto en seguridad informática en la CIA, Agencia Central de Inteligencia), la combinación para un mayor anonimato es utilizar a la vez una conexión VPN y Tor.

5.2. Tecnologías VPN y protocolos

Para realizar un buen diseño de una VPN, es necesario utilizar varios métodos para que los datos y conexión sean seguros:

- **Confidencialidad de datos:**

Puesto que los datos se transmiten por una red pública, este servicio es el más importante que debe ofrecer una VPN, mediante el cifrado de datos.

Estos son los protocolos que se pueden utilizar para proporcionar cifrado:

- **IPsec:**

Protocolo de seguridad de protocolos de Internet (IPsec) proporciona funciones de seguridad mejorada como algoritmos de cifrado más potentes y autenticación integral.



Tiene dos modos de cifrado:

- » Túnel: cifra el encabezado y la carga de cada paquete.
- » Transporte: solo cifra la carga.

- PPTP/MPPE:

PPTP admite VPN multiprotocolo, con cifrado de 40 bits y 128 bits mediante un protocolo denominado Cifrado de punto a punto de Microsoft (MPPE).

PPTP no proporciona cifrado de datos por su cuenta.

PPTP fue creado por el foro de PPTP, (consorcio que incluye US Robotics, Microsoft, 3COM, Ascend y ECI Telematics).

- L2TP/IPsec:

Denominado comúnmente L2TP a través de IPsec.

Proporciona la seguridad del protocolo de IPsec a través de los túneles de Protocolo de túneles de capa 2 (L2TP).

- **Integridad de los datos:**

Hay que verificar que los datos no se hayan modificado mientras están en tránsito, (que llegue la información correctamente).

- **Autenticación de origen de datos:**

Hay que verificar la identidad de la fuente de los datos que se envían.

- **Control antirreproducción:**

Es la capacidad para detectar y rechazar paquetes reproducidos y ayudar a evitar la suplantación de identidad.

- **Confidencialidad de tráfico/tunelizado de datos:**

El tunelizado es el proceso de encapsular un paquete entero dentro de otro paquete y enviarlo a través de una red, resulta útil en casos en los que se recomienda ocultar la identidad del dispositivo que originó el tráfico.

El tunelado requiere tres protocolos diferentes.

- Protocolo de pasajero: los datos originales (IPX, NetBeui, IP) que se transportan.
- Protocolo de encapsulación: protocolo (GRE, IPsec, L2F, PPTP, L2TP) que envuelve los datos originales.
- Protocolo de transporte: protocolo utilizado por la red a través de la cual viaja la información.



- **AAC (Autenticación, autorización y cuenta):**

Hay que crear un entorno de VPN seguro en acceso remoto.

Se debe realizar una autenticación de usuario, con nombre de usuario y contraseña válidos antes de completar la conexión remota, evitando que cualquiera pueda con un equipo con software de cliente VPN bien configurado, establecer una conexión a la red remota.

- **No rechazo:**

Se utiliza para evitar que un remitente niegue que ha realizado un envío de información, funciona agregando una firma digital en el mensaje enviado.

Especialmente en transferencias de datos financieras, utilizar la función de no rechazo es muy aconsejable, evitando que una de las partes niega haber participado en una transacción.

Al igual que un banco requiere la firma en un cheque para entregar el importe, el no rechazo (al agregar una firma digital en el mensaje enviado), impide la posibilidad de que el remitente niegue participación en la transacción.



+ Info

Has estudiado con más detalle alguno de los protocolos que hemos nombrado, en la unidad 7 "MODELO ISO/OSI, TCP/IP. PROTOCOLOS".

5.2.1. Protocolo L2TP

L2TP (Layer 2 Tunneling Protocol) es un protocolo utilizado por redes privadas virtuales que fue diseñado por un grupo de trabajo de IETF como el heredero aparente de los protocolos PPTP (RFC 2637) y L2F, creado para corregir las deficiencias de estos protocolos y establecerse como un estándar aprobado por el IETF (RFC 2661).

L2TP utiliza PPP para proporcionar acceso telefónico que puede ser dirigido a través de un túnel por Internet hasta un punto determinado. L2TP define su propio protocolo de establecimiento de túneles.

- **PAP, Password Authentication Protocol.**

Es un protocolo simple de autenticación para autenticar un usuario contra un servidor de acceso remoto o contra un proveedor de servicios de internet.



PAP es un subprotocolo usado por la autenticación del protocolo PPP (Point to Point Protocol), validando a un usuario que accede a ciertos recursos.

PAP transmite contraseñas o passwords en ASCII sin cifrar, por lo que se considera inseguro. PAP se usa como último recurso cuando el servidor de acceso remoto no soporta un protocolo de autenticación más fuerte.

- **CHAP**, Challenge Handshake Authentication Protocol.

Es un protocolo de autenticación por desafío mutuo y fue definido en la RFC 1994.

- **EAP**, Extensible Authentication Protocol.

Es un framework de autenticación usado habitualmente en redes WLAN Point-to-Point Protocol. Aunque el protocolo EAP no está limitado a LAN inalámbricas y puede ser usado para autenticación en redes cableadas, es más frecuente su uso en las primeras.

Recientemente los estándares WPA y WPA2 han adoptado cinco tipos de EAP como sus mecanismos oficiales de autenticación.

Es una estructura de soporte, no un mecanismo específico de autenticación.

Provee algunas funciones comunes y negociaciones para el o los mecanismos de autenticación escogidos. Estos mecanismos son llamados métodos EAP, de los cuales se conocen actualmente unos 40.

Además de algunos específicos de proveedores comerciales, los definidos por RFC de la IETF incluyen EAP-MD5, EAP-OTP, EAP-GTC, EAP-TLS, EAP-IKEv2, EAP-SIM, y EAP-AKA.

Es un método de autenticación remota o inalámbrica. Diversos proveedores de servicios emplean CHAP. Por ejemplo, para autenticar a un usuario frente a un ISP.

5.2.2. Protocolo IKE para VPN

IKE es un protocolo de nivel de aplicación sobre UDP en el puerto 500 y/o 4500.

Se construye sobre el de intercambio de claves de Internet (Internet Security Association and Key Management Protocol (ISAKMP), siendo una mejora de este.

Es un protocolo de tunelización, que establece y mantiene dinámicamente un estado compartido entre los puntos finales de un datagrama IP.

Simplifica la configuración de IPSec ya que establece una SA en IPSec.

Fases IKE:

- **Primera fase:**

Se establece el canal seguro utilizando claves Diffie-Hellman para generar una clave secreta que se usará para cifrar las comunicaciones IKE.



Para ello se establece una IKE_SA bidireccional (asociación de seguridad para intercambiar mensajes IKE).

La autenticación se puede realizar con diferentes mecanismos: pre-shared-key, PKI.

- **Segunda fase:**

Los extremos usan el canal seguro para establecer SA para IPSec, lo que se denomina CHILD_SA.

Versiones

La versión 2 ha sido desarrollada por IETF (RFC4306) para mejorar la función de realizar la autenticación de socio y el intercambio de claves dinámico para VPN, proporciona respecto a la versión 1:

- Una interfaz más sencilla y eficiente.
- Simplificación de los flujos de intercambio de claves.
- Nuevas medidas para arreglar ambigüedades y vulnerabilidades.

Tanto la versión 1 como la versión 2 de IKEv, negocian un conjunto de atributos de asociaciones de seguridad para el proceso de protocolos ESP y AH.

Ambas versiones operan en dos fases:

- La primera fase de IKEv2 es IKE_SA.

Consta del par de mensajes IKE_SA_INIT.

Los atributos de la fase IKE_SA se definen en la Política de intercambio de claves.

IKE_SA es comparable a la Fase 1 de IKEv1.

- La segunda fase de IKEv2 es CHILD_SA.

El primer CHILD_SA es el par de mensajes IKE_AUTH.

Pueden enviarse pares de mensajes CHILD_SA adicionales para mensajes informativos y de redefinición de claves.

Los atributos de CHILD_SA se definen en la Política de datos.

Esta fase es comparable a la Fase 2 de IKEv1.



Comparativa de las fases en IKEv1 e IKEv2

Para IKEv2 IKE_SA se produce un único intercambio de un par de mensajes, pero la Fase 1 de IKEv1 tiene dos intercambios posibles:

- Modalidad principal.
- Modalidad agresiva.

IKEv2 realiza un intercambio simple de dos pares de mensajes para CHILD_SA y IKEv1 requiere como mínimo un intercambio de tres pares de mensajes para la Fase 2.

Comparativa con otros protocolos

- IKEv2 se empareja con IPsec por sus prestaciones para proteger el tráfico de internet.
Ambos funcionan en conjunto para crear un protocolo VPN.
- IKEv2 y L2TP/IPsec ofrecen el mismo nivel de seguridad, porque ambos funcionan en torno a Ipsec.
Pero IKEv2 es compatible con menos sistemas y softwares.
- Tanto IKEv2 como OpenVPN ofrecen niveles similares de protección y seguridad.
IKEv2 gracias a su menor nivel de uso del CPU debería ser más rápido que OpenVPN.
OpenVPN es menos propenso a resultar bloqueado por cortafuegos cuando se conecta mediante TCP.

5.2.3. Protocolo WireGuard para VPN

Protocolo VPN de código abierto que utiliza criptografía de última generación.

Su objetivo es superar a los protocolos VPN existentes como IPsec y OpenVPN, convirtiéndose en una de las soluciones más seguras, rápidas y fáciles de usar en la industria de las VPN.

Al igual que en el protocolo IKEv2, el tráfico de WireGuard puede ser bloqueado por cortafuegos, puesto que solo utiliza UDP que puede ser bloqueado por los administradores de su red.

5.2.4. OpenVPN (Protocolo y Software)

OpenVPN es tanto un protocolo VPN como un software que utiliza técnicas VPN para asegurar conexiones punto a punto y de sitio a sitio.

Actualmente, es uno de los protocolos VPN más populares entre los usuarios de VPN.



Programado por James Yonan y lanzado en 2001, OpenVPN es uno de los únicos protocolos VPN de código abierto (open source) que también tiene su propia aplicación de código abierto (SoftEther es el otro).

El protocolo OpenVPN es responsable de manejar las comunicaciones cliente-servidor. Básicamente, ayuda a establecer un "túnel" seguro entre el cliente VPN y el servidor VPN usando el estándar SSL/TLS.

Cuando OpenVPN maneja el cifrado y la autenticación, usa la biblioteca OpenSSL de manera bastante extensa.

Además, OpenVPN puede usar UDP (Protocolo de Datagramas de Usuario) o TCP (Protocolo de Control de Transmisión) para transmitir datos.



Ejemplo

Al principio, Netflix tenía muy pocos contenidos en España. Sin embargo, en E.E.U.U. tenía una gran cantidad de películas y series.

Netflix controla tu IP y te ofrece los servicios de tu país.

Sin embargo, si te conectas a un servidor VPN de E.E.U.U., al conectarte a Netflix creará que estás en Estados Unidos y te ofrecerá el servicio de ese país.

Si no está familiarizado con TCP y UDP, son protocolos de capa de transporte y se utilizan para transmitir datos en línea.

TCP es más estable ya que ofrece funciones de corrección de errores (cuando se envía un paquete de red, TCP espera la confirmación antes de enviarlo nuevamente o enviar un nuevo paquete).

UDP no realiza corrección de errores, lo que lo hace un poco menos estable, pero mucho más rápido.

OpenVPN funciona mejor que UDP (de acuerdo con OpenVPN.net), por lo que el Servidor de Acceso de OpenVPN primero intenta establecer conexiones UDP. Si esas conexiones fallan, solo entonces el servidor intenta establecer conexiones TCP.

La mayoría de los proveedores de VPN también ofrecen OpenVPN sobre UDP por defecto.

Debido a la forma en que está programado (es un protocolo de seguridad personalizado), el protocolo OpenVPN puede omitir fácilmente HTTP y NAT.



Este protocolo no es compatible con IPSec, IKE, PPTP y L2TP.



+ Info

Consulta la información indicada por el organismo CCN:

CCN-STIC 836: Seguridad en Redes Privadas Virtuales (VPN)

<https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/2299-ccn-stic-836-seguridad-en-vpn-en-el-marco-del-ens/file.html>

5.3. Tipos de VPN

Como una primera clasificación, la conocida inicialmente, dependiendo del objetivo de la conexión, se pueden distinguir dos tipos de conexiones VPN: VPDN y VPN Site-to-Site.

Vamos a ver con detalle a continuación diferentes tipos de VPN:

- **VPDN, VPN de acceso remoto (Road Warrior):**

Como hemos indicado, es una de las clasificaciones iniciales que se hicieron de VPN, junto con VPN Sitio a Sitio.

VPDN son las siglas de Virtual Private Dial-up Network, también denominada Red telefónica privada virtual, o Acceso Remoto.

Se trata de una conexión de usuario a LAN utilizada para empleados que necesitan trabajar en su empresa desde diferentes ubicaciones remotas.

Permiten la conexión directamente a la red local de la empresa (o doméstica), y tener acceso a todos los recursos compartidos que existan, como si estuviéramos físicamente en la empresa. utilizando Internet como vínculo de acceso, una vez realizada una autenticación.

Las VPN de acceso remoto también pueden usarse para aislar ciertas zonas y servicios de la red interna, así, solamente conectándonos a través de la VPN se podrá tener acceso a esos determinados servicios.



También podríamos utilizar esto para añadir una capa más de seguridad a las redes inalámbricas Wi-Fi, (ante vulnerabilidades como por ejemplo KRACK), por ejemplo, si ubicamos un servidor de archivos con información sensible detrás de un servidor VPN, este proporcionará autenticación y cifrado adicional, para que solo el personal acreditado pueda acceder a la información, dificultando los posibles ataques.

Con los protocolos VPN para Road Warrior, como son IPsec, OpenVPN, y el protocolo VPN WireGuard, resultan fáciles de configurar y utilizar.

- **VPN Site-to-site (Sitio a sitio).**

Denomina también VPN de rúter a rúter, crea un puente virtual que une redes en diferentes lugares para conectarlas a internet y mantener una comunicación segura y privada entre ellas.

Permiten establecer un túnel entre dos sedes remotas, de forma que cualquier persona de una sede pueda tener visibilidad sobre la otra.

La puerta de enlace VPN encapsula y encripta el tráfico saliente para todo el tráfico de un sitio en particular, después envía el tráfico a través de un túnel VPN a través de Internet a una puerta de enlace VPN en el sitio de destino. Cuando la puerta de enlace VPN receptora recibe la información descripta el contenido y retransmite el paquete hacia el usuario de destino dentro de su red privada.

Las diferentes sedes pueden utilizar diferente autenticación, pero estas siempre se deben corresponder con la autenticación que tengamos configurada en el servidor VPN «central», para que la conexión se negocie adecuadamente.

Su uso común es en empresas con sucursales ubicadas físicamente dentro y/o fuera del país, las cuales utilizan una VPN de sitio a sitio para conectar la red de la oficina principal con el resto de sucursales, (conocido como VPN basada en intranet. Si las empresas utilizan estas VPN de la misma forma, pero para conectarse con otras compañías, se clasifica como una VPN basada en extranet.

Las VPN de sitio a sitio generalmente utilizan el protocolo IPsec, pero también es posible utilizar otros protocolos VPN que permitan una gran configurabilidad como OpenVPN.

- **VPN PPTP.**

PPTP es la abreviatura de Point-to-Point Tunneling Protocol, significa Protocolo de Túnel Punto a Punto, y es especificado en el documento RFC 2367.

Este tipo de VPN, crea un túnel y captura los datos, pero tiene dos desventajas a destacar:

- No ofrece codificación.
- No ofrecen confidencialidad e integridad de los datos.
- Depende del protocolo de punto a punto para implementar medidas de seguridad.



Suelen utilizarse por usuarios remotos para conectarse a la red de VPN mediante su red de internet existente, utilizando un inicio de sesión con contraseña.

Son compatibles con Windows, Mac y Linux.

- **VPN L2TP.**

L2TP es la abreviatura de Layer to Tunneling Protocol, traducido como Protocolo de Establecimiento de Túneles, y fue desarrollado por Microsoft y Cisco.

Se combina con otro protocolo de seguridad de VPN para establecer una conexión más segura.

- Una VPN L2TP forma un túnel entre dos puntos de conexión L2TP.
- Otra VPN (como el protocolo ipsec) encripta los datos y se focaliza en asegurar la comunicación entre los túneles.

Al igual que PPTP, no tiene encriptación y depende de protocolos PPP para implementar seguridad, pero las VPN L2TP sí que brindan confidencialidad e integridad de los datos.

- **VPN IPsec.**

Utiliza el protocolo IPSec, que se usa para proteger la comunicación por internet a través de una red IP, estableciendo un túnel en un sitio remoto que permite el acceso al sitio central.

Una VPN IPsec funciona verificando cada sesión y codificando individualmente los paquetes de datos durante la conexión.

Para proteger la transferencia de datos entre dos redes diferentes, hay dos modos en los que opera una VPN IPsec:

- El de transporte.

Se codifica el mensaje en el paquete de datos.

El de túnel.

- Todo el paquete de datos está encriptado.

Las VPN IPsec requieren un equipamiento por parte del cliente, generalmente un router o aparato de seguridad multipropósito, donde se codifican los datos y se forma el túnel VPN.

Una VPN IPsec también puede emplearse junto con otros protocolos de seguridad para ofrecer un sistema todavía más robusto, pero requiere instalaciones costosas y que requieren mucho tiempo en el lado cliente, ya que debe existir antes de su uso.



- **VPN SSL y TLS.**

Utiliza los protocolos SSL (Secure Sockets Layer) y TLS (Transport Layer Security) para crear una conexión VPN.

En esta conexión, el navegador web funciona como cliente, y el acceso del usuario está restringido a aplicaciones específicas en lugar de poder acceder a toda la red.

Una VPN SSL y TLS ofrece una sesión segura desde el navegador del ordenador del usuario hacia el servidor de la aplicación, debido a que los navegadores web (con SSL y TLS integrado) cambian a SSL con facilidad sin requerir casi ninguna acción por parte del usuario.

Cuando la conexión a Internet es SSL tienen https al inicio de la dirección URL en lugar de http.

Este tipo de VPN es muy utilizado en sitios webs de compras.

- **VPN MPLS.**

MPLS, siglas de Multiprotocol Label Switching, traducido como conmutación de etiquetas multiprotocolo.

Es una técnica que unifica la transferencia de diferentes tipos de datos a través de una misma red, con el fin de superar las limitaciones de velocidad y mejorar el flujo de trabajo de Internet.

Son sistemas que están ajustados a ISP, lo que significa que dos o más sitios están conectados para formar una VPN utilizando el mismo ISP.

Se utiliza para acelerar la distribución de paquetes de red en múltiples protocolos.

Su configuración es más difícil que en otras VPN, por lo que su utilización suele ser generalmente más costosa.

- **VPN Híbrida.**

Este tipo de VPN, combina MPLS y VPN basada en protocolo IPsec, con el objetivo de utilizar la VPN IPsec como un respaldo de la VPN MPLS.

Con esta combinación se establece un portal para eliminar el túnel IPsec en un lado y trazarlo hacia la VPN MPLS en el otro extremo, preservando así la seguridad que es el objetivo a conseguir.



+ Info

Lo normal es contratar un servicio de VPN, pero también es posible crear uno propio para tener un control absoluto, aunque esto es bastante complicado.



Si se quiere crear un servidor VPN propio, (ya sea en un ordenador con Windows o en un servidor remoto), una de las mejores opciones es utilizar OpenVPN, (herramienta de conectividad de software libre).

6. Protocolo RADIUS

RADIUS (acrónimo en inglés de Remote Authentication Dial-In User Service) es un **protocolo de autenticación y autorización para aplicaciones de acceso a la red o movilidad IP**. Utiliza el puerto 1812 UDP para establecer sus conexiones.

Cuando se realiza la conexión con un ISP (proveedor de servicios de Internet) mediante módem, DSL (línea de abonado digital, o ADSL acrónimo en inglés de Asymmetric Digital Subscriber Line), cabledmódem, Ethernet o Wi-Fi:

- Se envía una información que generalmente es un nombre de usuario y una contraseña.
- Esta información se transfiere a un dispositivo Network Access Server (NAS) sobre el protocolo PPP, quien redirige la petición a un servidor RADIUS sobre el protocolo RADIUS.
- El servidor RADIUS comprueba que la información es correcta utilizando esquemas de autenticación como PAP, CHAP o EAP.
 - Si es aceptado, el servidor autorizará el acceso al sistema del ISP y le asigna los recursos de red como una dirección IP, y otros parámetros como L2TP, etc.

Una de las características más importantes del protocolo RADIUS es su capacidad de manejar sesiones, notificando cuándo comienza y termina una conexión, así que al usuario se le podrá determinar su consumo y facturar en consecuencia; los datos se pueden utilizar con propósitos estadísticos.

RADIUS fue desarrollado originalmente por Livingston Enterprises para la serie PortMaster de sus Servidores de Acceso a la Red (NAS), más tarde se publicó como RFC 2138 y RFC 2139.

Actualmente existen muchos servidores RADIUS, tanto comerciales como de código abierto.

Las prestaciones pueden variar, pero la mayoría pueden gestionar los usuarios en archivos de texto, servidores LDAP, bases de datos varias, etc.

A menudo se utiliza SNMP para monitorear remotamente el servicio.



Los servidores Proxy RADIUS se utilizan para una administración centralizada y pueden reescribir paquetes RADIUS al vuelo (por razones de seguridad, o hacer conversiones entre dialectos de diferentes fabricantes).

RADIUS es extensible; la mayoría de fabricantes de software y hardware RADIUS implementan sus propios dialectos.

Estándares

El protocolo RADIUS actualmente está definido en los RFC 2865 (autenticación y autorización) y RFC 2866 (accounting).

Otros RFC relevantes son:

- RFC 2548
- RFC 2607
- RFC 2618
- RFC 2619
- RFC 2620
- RFC 2621
- RFC 2809
- RFC 2867
- RFC 2868
- RFC 2869
- RFC 2882
- RFC 3162
- RFC 3576.1.1.
- Puesta en funcionamiento de un servidor RADIUS



Ventajas y Funciones

Una de las ventajas es la versatilidad existente, este servicio funciona a través del puerto UDP 1812.

Existe una gran variedad de dispositivos que se pueden utilizar, muchos routers son capaces de ofrecer este servicio.

Los operadores de servicios de Internet, lo utilizan para que los routers domésticos de los usuarios se autenticuen y así acceder al recurso de red que en esta ocasión les permite el acceso a Internet.

Este servidor y protocolo, tiene como uso por excelencia garantizar el acceso restringido a las redes inalámbricas, lo que lo hace muy utilizado en Hostelería, establecimientos hoteleros, colegios, bibliotecas etc. donde los responsables de administración de la red generan unas credenciales temporales que permiten el acceso limitado en lo que se refiere a temporalidad. Una vez sobrepasada la fecha fijada, las credenciales no tendrán vigencia y el servidor RADIUS no validará la utilización de la red.

También pueden utilizarse servidores, OLTs, y servidores NAS.

Radius ofrece un mecanismo de autenticación de usuarios para acceder a un recurso compartido, permitiendo autorizar a un usuario a este recurso. A continuación, se produce el Accounting, análisis del tiempo de la sesión y registros estadísticos.

Relación con WPA3-Enterprise y EAP-TLS

WPA3-Enterprise es una versión del protocolo de seguridad Wi-Fi WPA3 diseñada para entornos empresariales y de gran escala. A diferencia de WPA3-Personal, que utiliza una clave compartida para la autenticación, WPA3-Enterprise se basa en mecanismos de autenticación más robustos como EAP (Extensible Authentication Protocol), que se utiliza para permitir la autenticación mutua entre el cliente y el servidor.

EAP-TLS (Extensible Authentication Protocol - Transport Layer Security) es uno de los métodos de autenticación más seguros y utilizados en WPA3-Enterprise. Para usar este protocolo, es necesario un servidor RADIUS (Remote Authentication Dial-In User Service), que proporciona la autenticación centralizada, gestionando las credenciales de acceso y validando la identidad de los usuarios que intentan conectarse a la red Wi-Fi.

Por lo tanto, para acceder a la red Wi-Fi con WPA3-Enterprise, se debe utilizar un servidor RADIUS o una solución compatible con EAP-TLS, lo que garantiza un alto nivel de seguridad en la autenticación de los dispositivos.

7. Acceso remoto seguro a redes

En cualquier empresa, independientemente de su tamaño y actividad, la posibilidad de disponer de la información en todo momento se está convirtiendo en una necesidad.

Cada vez cobra más importancia el poder acceder a la documentación desde ubicaciones remotas como, por ejemplo, la oficina de un cliente o el propio domicilio.



En este sentido, el acceso remoto a los datos lleva consigo una influencia positiva sobre el negocio.

Esta se centra en dos aspectos:

- La posibilidad de realizar cualquier acción sobre la plataforma informática desde un lugar distinto de la oficina habitual.
- La flexibilidad temporal a la que se dota al personal para realizar su actividad.

Con la implementación de este tipo de servicio, y enfocado a tareas determinadas, la empresa puede conseguir muchos beneficios.

Por ello, para implementar un sistema que permita conectarse en remoto es imprescindible contar con una estructura tecnológica determinada y aplicar las políticas de seguridad que garanticen el correcto funcionamiento de la plataforma.

Como es imposible controlar desde dónde se conectará un terminal (portátil, Smartphone, etc.) remotamente, se han de implementar mecanismos que garanticen la autenticación, confidencialidad e integridad de los datos durante la comunicación.

Esto es posible con la tecnología de «Red Privada Virtual» (VPN) que permite extender la red local sobre una red no controlada como Internet.

Existen soluciones tanto hardware como *software* para implementar redes privadas virtuales con distintos protocolos (IPSec, SSH, L2F, etc.) para cifrar los datos que viajan entre la conexión.

El protocolo más extendido es el SSL/TSL. Estos protocolos permiten a las aplicaciones comunicarse evitando escuchas, la falsificación de la identidad del remitente (*phishing*) y la alteración de la integridad del mensaje.

Otro aspecto muy importante a la hora de implementar un acceso remoto es definir las políticas de seguridad y los perfiles de usuarios. Las políticas de seguridad garantizan los derechos de acceso a los datos y recursos con herramientas de control y mecanismos de identificación.

Se trata de establecer normas, franjas horarias, etc. para permitir el acceso al usuario sólo a aquellos recursos que necesitan para su trabajo y decidir la forma de actuar en caso de incidente.

En cuanto a los perfiles, establecen las características propias de un conjunto de usuarios con permisos particulares sobre los distintos recursos. No debe tener los mismos derechos un usuario de la propia empresa que un colaborador externo, o si se accede desde un móvil o desde un PC.



Recuerda

Kerberos.

Es un protocolo de autenticación de redes de ordenador creado por el MIT que permite a dos ordenadores en una red insegura demostrar su identidad mutuamente de manera segura.



Sus diseñadores se concentraron primeramente en un modelo de cliente-servidor, y brinda autenticación mutua: tanto cliente como servidor verifican la identidad uno del otro.

2FA (Doble Factor de Autenticación)

El Doble Factor de Autenticación, obligará al usuario a facilitar dos maneras distintas de verificar su identidad antes de poder acceder a los recursos ofrecidos. El 2FA es un tipo de validación que puede ser utilizada en multitud de contextos diferentes, acceso a redes privadas, a aplicaciones móviles, a correo electrónico, a servidores en la nube, plataformas de desarrollo, CMS, portales web, banca online, etc.

Su diseño implemente generalmente dos de las tres categorías mencionadas a continuación, conocimiento, posesión e identidad personal.

- **Conocimiento:** p.e usuario/contraseña.
- **Posesión:** token o código de autenticación enviado al móvil vía SMS o al correo electrónico.
- **Identificación personal:** huella digital. iris, etc.

Es muy común hoy día que para acceder a nuestra banca online o a una VPN se nos solicite la doble autenticación, primero con la solicitud de usuario y contraseña y a continuación un código enviado vía SMS o email.

Portal Cautivo

Herramienta que se utiliza fundamentalmente en los entornos públicos o semipúblicos tipo cafeterías, campings, piscinas, aeropuertos u hoteles. El portal cautivo nos ayudará a garantizar la seguridad mediante la autenticación de los usuarios que accedan a la red.

La herramienta, redirigirá a una página web concreta al usuario que intente conectarse a la red Wi-Fi. En esta página el usuario suele ser conminado a autenticarse de alguna manera, generalmente con usuario y contraseña y aceptar asimismo determinadas condiciones. Si las credenciales del usuario son válidas, automáticamente será redirigido al servicio al trataba de acceder.



8. Seguridad en el puesto del usuario



Fuente: social-media-internet-security-global-thumbnail de Piquesels

Podemos, de una forma fácil y sencilla, seguir unas medidas de seguridad básicas para proteger nuestros sistemas informáticos, tanto a nivel de información, que es el activo más importante, como también a nivel de software, ya que fallos en su funcionamiento perjudican a la productividad.

Aunque estas medidas ya se han estudiado en unidades anteriores, debido a su importancia vamos a recordarlas.

8.1. Control de acceso a la información

Por defecto, toda organización debe seguir el principio del mínimo privilegio.

Este principio se traduce en que un usuario sólo debe tener acceso a aquella información estrictamente necesaria para desempeñar sus funciones diarias.

Para conseguir este objetivo debemos realizar los siguientes pasos:

- Definir los diferentes tipos de información que existen en nuestra organización.
- Establecer quién puede acceder a cada tipo de información.

La asignación de permisos sobre los recursos que contienen la información puede realizarse:

- Individualmente.
- Por perfiles.
- Por grupos de usuarios.

Es vital escoger medios que permitan la trazabilidad y que sean proporcionales al volumen de información.



Recuerda

Otra forma de controlar el acceso a los recursos son los "Token de seguridad".

Un token de seguridad (también llamado llave digital o llave electrónica) es un dispositivo físico utilizado para acceder a un recurso restringido electrónicamente.

El token se utiliza como complemento o en lugar de una contraseña.

8.2. Copias de seguridad

La realización de copias de seguridad, es imprescindible, y deben estar bien planificadas, gestionadas y controladas. Por ello se debe:

- Diseñar la política de seguridad.
- Determinar qué información se va a guardar.
- Concienciar a los usuarios de que deben guardar los documentos a respaldar en las carpetas habilitadas para ello. Se realizarán copias de seguridad de estas carpetas.
- Programar una ejecución automatizada y supervisarla.
- Realizar pruebas de recuperación para asegurar que las copias se están realizando correctamente.
- Recuperar información ante fallos o cuando un usuario lo requiera.

Recordemos los tres tipos básicos de copias de seguridad diarias, y un ejemplo:

- **Completa:** copia toda la información.
- **Incremental:** copia toda la información que ha cambiado desde la última copia completa o incremental.
- **Diferencial:** copia toda la información que ha cambiado desde la última copia completa incluidos los archivos eliminados.

Ejemplo: Supongamos que los lunes y jueves hacemos una copia completa de datos. A los datos que tenemos el lunes les llamaremos "A".



Datos añadidos o modificados	Completa	Incremental	Diferencial
Lunes (Datos a copiar "A")	A	-	-
Martes (datos nuevos "B")	-	B	B
Miércoles (datos nuevos "C")	-	C	B+C
Jueves (datos nuevos "D")	A+B+C+D	-	-
Viernes (datos nuevos "E")	-	E	E
Sábado (datos nuevos "F")	-	F	E+F
Domingo (datos nuevos "G")	-	G	E+F+G

8.3. Gestión de contraseñas



Fuente: (<https://pixabay.com/es/internet-de-seguridad-contrase%C3%B1a-1952019/>)

La gestión de usuarios y contraseñas es la primera línea de defensa frente al acceso no autorizado.

Debemos determinar una serie de condiciones de seguridad mínimas en cuanto a las características de las contraseñas, así como periodos de renovación de estas.

Todas estas condiciones y medidas de seguridad deberían estar definidas en la política de seguridad de la organización.

Las contraseñas deben ser robustas y secretas. Para ello:

- Deben tener una longitud adecuada. (A mayor número de caracteres, mayor dificultad de obtenerla con algoritmos de fuerza bruta).
- Longitud mínima de ocho caracteres.



- No deben utilizarse palabras conocidas:

- Palabras del diccionario.
- Nombres propios.
- Lugares.

Las contraseñas con estas palabras son más fáciles de romper con ataques de diccionario.

- Las contraseñas deben incluir variedad de caracteres:

- Mayúsculas.
- Minúsculas.
- Números.
- Signos de puntuación.

- No se deben reutilizar claves. Cada servicio que usemos debe tener una clave diferente.

Se deberían establecer políticas de seguridad que obliguen a los usuarios a cambiar la contraseña periódicamente, evitando la reutilización de estas.

En Windows, esto se puede definir mediante las directivas de contraseña.



Recuerda

El Centro Criptológico Nacional (CCN) ha redactado una guía/norma de seguridad de las TIC (CCN-STIC-400).

Aconsejamos encarecidamente su lectura.

Quizás la parte de criptografía sea demasiado detallada, pero el resto es realmente interesante.

<https://www.ccn-cert.cni.es/series-ccn-stic/guias-de-acceso-publico-ccn-stic/4-ccn-stic-400-manual-stic/file.html>



8.4. Single Sign-On

El "Inicio de Sesión Único" o "Inicio de Sesión Unificado" (Single Sign-On, SSO) es un procedimiento de autenticación que habilita a un usuario determinado para acceder a varios sistemas con una sola instancia de identificación.

Hay cinco tipos principales de Single Sign-On, llamados también *reduced sign on systems* ("sistemas de autenticación reducida"):

- **Enterprise SSO (E-SSO).**

Denominado también Legacy SSO, funciona para una autenticación primaria, interceptando los requisitos de login presentados por las aplicaciones secundarias para completar los mismos con el usuario y contraseña.

Estos sistemas E-SSO permiten interactuar con sistemas que pueden deshabilitar la presentación de la pantalla de login.

- **Web SSO (Web-SSO).**

Denominada también gestión de acceso web (web access management, Web-AM o WAM) trabaja solamente con aplicaciones y recursos accedidos vía web.

Su objetivo es permitir autenticar a los usuarios en diversas aplicaciones, sin necesidad de volver a autenticarse, por ello los accesos son interceptados con la ayuda de un servidor proxy o de un componente instalado en el servidor web o en la aplicación web destino.

Los usuarios no autenticados que tratan de acceder son redirigidos a un servidor o servicio web de autenticación y regresan solamente después de haber logrado un acceso exitoso o con un TOKEN de autenticación para la aplicación destino.

Se utilizan cookies, parámetros por GET (más inseguro) o POST para reconocer aquellos usuarios que acceden y su estado de autenticación.

- **Kerberos.**

Es un método popular de externalizar la autenticación de los usuarios. Los usuarios se registran en el servidor Kerberos y reciben un tique, luego las aplicaciones cliente lo presentan para obtener acceso.

- **Identidad federada.**

Utiliza protocolos basados en estándares para habilitar que las aplicaciones puedan identificar los clientes sin necesidad de autenticación redundante.

Es una nueva forma de enfrentar el problema de la autenticación, también para aplicaciones Web.

- **OpenID.**

Es un proceso de SSO distribuido y descentralizado donde la identidad se compila en un Localizador Uniforme de Recursos (URL) que cualquier aplicación o servidor puede verificar.



8.5. Antivirus (EPP y EDR)

Una de las medidas más relevantes para proteger el puesto del usuario frente a ciberataques es el uso de antivirus. Estas soluciones han evolucionado desde los programas clásicos que detectaban malware por firmas hasta plataformas avanzadas que integran análisis en tiempo real, monitorización del comportamiento y respuesta automatizada. Actualmente distinguimos dos grandes categorías: EPP (Endpoint Protection Platform) y EDR (Endpoint Detection and Response).

8.5.1. Endpoint Protection Platform (EPP)

Las EPP constituyen la primera línea de defensa en el puesto de usuario. Su función principal es prevenir infecciones antes de que estas lleguen a ejecutarse en el sistema. Para ello, incorporan diversas tecnologías: análisis por firmas tradicionales, detección heurística, control de aplicaciones, servicios en la nube y filtros de navegación.

Estas plataformas se gestionan de forma centralizada, lo que permite a la organización supervisar y actualizar las defensas de todos los dispositivos corporativos. En la práctica, un EPP puede bloquear un archivo adjunto malicioso en el correo electrónico o impedir la descarga de un programa no autorizado desde Internet.

Ejemplos de soluciones EPP:

- Symantec Endpoint Protection: combina antivirus clásico, firewall y control de aplicaciones.
- McAfee Endpoint Security: incluye protección contra amenazas web y administración centralizada.
- Kaspersky Endpoint Security: ofrece prevención frente a malware y control de dispositivos externos (USB).

8.5.2. Endpoint Detection and Response (EDR)

Las soluciones EDR surgen para complementar a las EPP. Mientras estas se centran en la prevención, el EDR se ocupa de la detección temprana y la respuesta rápida cuando una amenaza ha conseguido superar la primera barrera.

El EDR monitoriza de manera continua la actividad de los equipos, registrando procesos, conexiones y comportamientos sospechosos. Si detecta un patrón anómalo, puede reaccionar de forma automatizada: aislar el dispositivo de la red, detener un proceso malicioso o lanzar una alerta al centro de operaciones de seguridad.

Esto resulta esencial frente a ataques avanzados, como el ransomware, los ataques sin archivos (fileless) o los intentos de movimiento lateral en la red. En estos casos, el EDR permite contener el incidente y reducir su impacto.



Ejemplos de soluciones EDR:

- CrowdStrike Falcon: monitoriza continuamente los endpoints y ofrece respuesta automatizada en la nube.
- Microsoft Defender for Endpoint: integra capacidades EDR con protección en tiempo real dentro del ecosistema Windows.
- Sophos Intercept X: combina EPP y EDR en una sola herramienta, con capacidad de análisis de amenazas avanzadas.

9. Bibliografía

- <https://www.ccn-cert.cni.es/series-ccn-stic/guias-de-acceso-publico-ccn-stic/4-ccn-stic-400-manual-stic/file.html>
- https://www.incibe.es/extfrontinteco/img/File/demostrador/monografico_catalogo_proteccion_puesto_trabajo.pdf
- <https://www.incibe.es/protege-tu-empresa/blog/como-hacer-acceso-remoto-sea-seguro>
- https://es.wikipedia.org/wiki/Algoritmo_criptografico
- <https://www.incibe.es/protege-tu-empresa/blog/deberias-utilizar-red-privada-virtual-y-hacerlo>
- <https://www.ecured.cu/>
- <https://es.wikipedia.org/wiki/Kerberos>
- <https://www.redeszone.net/2016/01/28/suricata-3-0-novedades-de-este-nuevo-monitor-de-seguridad-libre/>

